



TLP:CLEAR



Logging Reference Architecture (LRA)

Publication: August 2026
Cybersecurity and Infrastructure Security Agency

This document is marked TLP:CLEAR. Recipients may share this information without restriction. Information is subject to standard copyright rules. For more information on the Traffic Light Protocol, see <https://www.cisa.gov/tlp>.

TLP:CLEAR

Table Of Contents

1. INTRODUCTION	1
1.1 Purpose.....	1
1.2 Background	2
1.3 Scope	4
1.3.1 In Scope.....	4
1.3.2 Out of Scope	5
2. HOW TO USE THE LRA	5
2.1 Intended Audience	6
2.2 Recommended Use Cases	6
3. SECURITY OUTCOMES.....	7
3.1 Continuous Event Monitoring.....	8
3.2 Threat Hunting	8
3.3 Incident Response.....	9
3.4 Digital Forensics	10
3.5 Measuring Logging Capability Readiness	10
4. ARCHITECTURAL DECISIONS	11
4.1 Telemetry Decisions.....	12
4.2 Collection Decisions	13
4.3 Telemetry Transportation	13
4.4 Normalization, Enrichment, and Schema Enforcement.....	14
4.5 Searchable, Retrievable, and Immutable Handling.....	15
4.6 Policy Enforcement	16
4.7 Logging Capability Observation, Validation, and Safe Changes.....	16
5. OPERATING MODEL AND DATAFLOW PATTERNS.....	17
5.1 Recommended Default Operating Model	17
5.2 Collection and Transport Patterns.....	18
5.3 Processing and Storage Placement Patterns	19
5.4 Common Architecture Patterns.....	20
5.4.1 Repository First	20
5.4.2 Dual Replication	20
5.4.3 Selective Feeds	21
5.4.4 SIEM First	21

5.4.5 Segregated-Access Overlay	21
5.5 Specialized Environment Patterns	21
6. BASELINE LOGGING COVERAGE AND MINIMUM EVENT FIDELITY	22
6.1 Baseline Logging Requirements	22
6.2 Minimum Event Fidelity	23
6.2.1 Identity and Authentication Activity	23
6.2.2 Network Activity	24
6.2.3 Object, Resource, and Data Activity	24
6.2.4 Privileged and Administrative Activity	24
6.2.5 Endpoint and System Activity	24
6.2.6 Security Tool Alerts and Detections	24
6.2.7 Cloud and SaaS Administrative Activity	25
6.2.8 High Value Assets and Specialized Environments	25
6.2.9 IoT and OT Device Activity (Including Environments Without Native Logging)	25
6.3 Common Fields Required for Operational Usability	25
6.4 Coverage and Fidelity Gaps That Materially Degrade Operations	26
7. SCHEMA, NORMALIZATION, AND INTEROPERABILITY	26
7.1 Normalization	27
7.2 Source-Native Context For Recoverability	27
7.3 Schema Governance and Change Management	28
7.4 Portability, Federal Interoperability, and Authorized Sharing	28
8. LOGGING INFRASTRUCTURE SECURITY, INTEGRITY, AND RESILIENCE	29
8.1 Protecting the Logging Infrastructure	29
8.2 Integrity Protections and Evidentiary Considerations	30
8.3 Resilience and Failure Handling	30
9. RISK-INFORMED LOGGING BEYOND THE BASELINE	31
9.1 Understanding Threat and Risk Profiles	31
9.2 Visibility-Informed Assessment of Current State	32
9.3 Method for Determining Above-Baseline Logging	32
9.4 Documenting Above-Baseline Decisions in the Agency Logging Plan	33
10. USING AI FOR CEM AND THIRF PRODUCTIVITY ENHANCEMENTS	33
10.1 Example Use Cases	34
11. MATURITY PROGRESSION FOR FEDERAL AGENCIES	34

11.1 Maturity Progression Stages.....	35
APPENDIX A: FEDERAL POLICY REFERENCE MAPPINGS.....	37
APPENDIX B: AGENCY LOGGING PLAN OVERVIEW	43
B.1 Agency Logging Plan Template	43
B.2 Minimum Plan Content.....	43
B.3 Agency Logging Plan Resources and Contacts	44
APPENDIX C: PRIORITY ARCHITECTURE AND DESIGN DECISION CHECKLIST.....	45
C.1 How to Use This Checklist	45
C.2 Outcome Alignment	45
C.2.1 Required Security Outcomes	45
C.2.2 Operational Questions	45
C.2.3 Enterprise Perspective	45
C.3 Scope and Coverage	45
C.3.1 Scope Definition.....	45
C.3.2 Baseline Coverage	46
C.3.3 Specialized and High-Value Environments	46
C.4 Telemetry Fidelity and Usability.....	46
C.4.1 Minimum Event Fidelity	46
C.4.2 Common Fields for Cross-Source Use	46
C.4.3 Operational Usability	46
C.5 Collection and Provenance.....	46
C.5.1 Collection Model	47
C.5.2 Provenance Preservation	47
C.5.3 Delivery Assurance	47
C.6 Transport and Dataflow	47
C.6.1 Transport Patterns.....	47
C.6.2 Durability and Replay.....	47
C.6.3 Enterprise Dataflow.....	47
C.7 Normalization, Enrichment, and Schema Governance.....	47
C.7.1 Normalized Event Representation	47
C.7.2 Recoverable Source-Native Context	48
C.7.3 Enrichment	48
C.7.4 Schema Governance	48

C.8 Storage, Searchability, and Retention	48
C.8.1 Searchable Operational Window.....	48
C.8.2 Retrievable Retention	48
C.8.3 Immutable or Evidentiary Handling	48
C.8.4 Storage Design Rationale	48
C.9 Security, Access, Minimization, and Sharing	49
C.9.1 Logging Infrastructure Protection	49
C.9.2 Integrity and Provenance	49
C.9.3 Access Control.....	49
C.9.4 Minimization and Redaction	49
C.9.5 Authorized Sharing.....	49
C.10 Validation, Observability, and Change Control	49
C.10.1 Coverage Validation	49
C.10.2 Timeliness and Quality Validation	49
C.10.3 Operational Usability Validation.....	50
C.10.4 Drift and Change Management	50
C.11 Above-Baseline Logging Decisions	50
C.11.1 Decision Basis.....	50
C.11.2 Investigative Use Case Linkage	50
C.11.3 Integration Into the Architecture	50
C.12 Maturity and Improvement	50
C.12.1 Current State.....	50
C.12.2 Improvement Priorities	50
C.12.3 Governance and Review.....	51
C.13 Reviewer Summary.....	51
APPENDIX D: BASELINE LOGGING CATEGORIES AND MINIMUM FIDELITY QUICK	
REFERENCE	52
D.1 How to Use This Appendix.....	52
D.2 Identity and Authentication Activity.....	52
D.2.1 Operational Purpose	52
D.2.2 Minimum Usable Fidelity.....	52
D.2.3 Additional Fidelity Often Needed	53
D.2.4 Common Operational Failure Modes	53
D.3 Network Activity	53

D.3.1 Operational Purpose	53
D.3.2 Minimum Usable Fidelity.....	53
D.3.3 Additional Fidelity Often Needed	54
D.3.4 Common Operational Failure Modes	54
D.4 Object, Resource, and Data Activity	54
D.4.1 Operational Purpose	54
D.4.2 Minimum Usable Fidelity.....	54
D.4.3 Additional Fidelity Often Needed	54
D.4.4 Common Operational Failure Modes	55
D.5 Privileged and Administrative Activity.....	55
D.5.1 Operational Purpose	55
D.5.2 Minimum Usable Fidelity.....	55
D.5.3 Additional Fidelity Often Needed	55
D.5.4 Common Operational Failure Modes	55
D.6 Endpoint and System Activity.....	56
D.6.1 Operational Purpose	56
D.6.2 Minimum Usable Fidelity.....	56
D.6.3 Additional Fidelity Often Needed	56
D.6.4 Common Operational Failure Modes	56
D.7 Security Tool Alerts and Detections.....	56
D.7.1 Operational Purpose	56
D.7.2 Minimum Usable Fidelity.....	57
D.7.3 Additional Fidelity Often Needed	57
D.7.4 Common Operational Failure Modes	57
D.8 Cloud and SaaS Administrative Activity	57
D.8.1 Operational Purpose	57
D.8.2 Minimum Usable Fidelity.....	57
D.8.3 Additional Fidelity Often Needed	58
D.8.4 Common Operational Failure Modes	58
D.9 High Value Assets and Specialized Environments	58
D.9.1 Operational Purpose	58
D.9.2 Minimum Usable Fidelity.....	58
D.9.3 Additional Fidelity Often Needed	58

D.9.4 Common Operational Failure Modes	59
D.10 Common Fields Required Across Categories	59
D.10.1 Minimum Common Field Set	59
D.10.2 Validation Prompts	59
D.11 Quick Gap Identification Prompts	59
D.11.1 Coverage.....	59
D.11.2 Fidelity	59
D.11.3 Searchability and Access.....	59
D.11.4 Correlation.....	60
D.12 IoT and OT Devices	60
D.12.1 Operational Purpose Support.....	60
D.12.2 Minimum Usable Fidelity	60
D.12.3 Additional Fidelity Often Needed.....	60
D.12.4 Common Operational Failure Modes.....	60
D.13 Recommended Use in Agency Logging Plans.....	60
APPENDIX E: VALIDATION AND OPERATIONAL READINESS CHECKLIST	61
E.1 How to Use This Checklist.....	61
E.2 Scope and Coverage Validation	61
E.2.1 In-Scope Environment Validation	61
E.2.2 Baseline Category Coverage Validation	62
E.2.3 High-Value and Specialized Environment Validation	62
E.3 Source Presence and Collection Validation	62
E.3.1 Source Onboarding Validation	62
E.3.2 Collection Integrity Validation	62
E.3.3 Gap Detection.....	62
E.4 Timeliness and Latency Validation.....	62
E.4.1 Event Arrival Timeliness.....	62
E.4.2 Delay and Backlog Detection.....	63
E.4.3 Polling and Retrieval Validation	63
E.5 Event Fidelity and Data Quality Validation	63
E.5.1 Minimum Field Validation	63
E.5.2 Timestamp Validation	63
E.5.3 Parsing and Mapping Validation	63

E.5.4 Fidelity Sufficiency Validation	63
E.6 Schema, Normalization, and Correlation Validation	63
E.6.1 Normalized Event Validation	64
E.6.2 Source-Native Context Validation	64
E.6.3 Entity Correlation Validation	64
E.6.4 Drift Detection Validation	64
E.7 Searchability and Retrieval Validation	64
E.7.1 Searchability Validation	64
E.7.2 Retrieval Validation	64
E.7.3 Searchability vs. Retrieval Distinction	64
E.8 Operational Usability Validation	65
E.8.1 Monitoring Use Case Validation.....	65
E.8.2 Threat Hunting Validation.....	65
E.8.3 Incident Response Validation	65
E.8.4 Digital Forensics Validation.....	65
E.9 Integrity, Provenance, and Access Validation	65
E.9.1 Integrity Control Validation.....	65
E.9.2 Provenance Validation	65
E.9.3 Access Control Validation	65
E.9.4 Minimization and Sharing Validation.....	66
E.10 Pipeline Health and Resilience Validation	66
E.10.1 Health Monitoring Validation	66
E.10.2 Partial Failure Validation.....	66
E.10.3 Buffering and Replay Validation	66
E.10.4 Single-Point Fragility Validation	66
E.11 Change Management and Regression Validation.....	66
E.11.1 Controlled Change Validation	66
E.11.2 Regression Testing.....	67
E.11.3 Post-Change Review	67
E.12 Exercises, Synthetic Tests, and Readiness Demonstrations	67
E.12.1 Synthetic Event Validation	67
E.12.2 Tabletop and Exercise Support Validation.....	67
E.12.3 Replay and Historical Validation	67

E.13 Gap Tracking and Improvement Validation 67

 E.13.1 Known Gap Visibility..... 67

 E.13.2 Remediation Tracking 68

 E.13.3 Maturity Progress Validation 68

E.14 High-Level Readiness Questions 68

APPENDIX F: ACRONYMS 69

1. INTRODUCTION

Federal agencies require logging capabilities that extend beyond mere data collection and retention. Logging capabilities must enable timely detection, effective threat hunting, decisive incident response, and robust digital forensics. The Cybersecurity and Infrastructure Security Agency (CISA) Logging Reference Architecture (LRA) provides actionable guidance for designing and evolving those capabilities in alignment with federal policy and operational needs.

This LRA assists agencies with translating federal logging requirements into implementable architecture and engineering decisions. Agencies should consider this LRA a product selection guide, a fixed deployment blueprint, or a restatement of policy; it is a practitioner-oriented reference for enterprise and security architects who must determine what telemetry the agency needs, how that telemetry should move through the logging infrastructure, how it must be protected and retained, and how the agency will validate that the capability is operationally effective, scalable, and sustainable. For the purposes of this guidance, “agency” has the meaning given in 44 U.S.C. § 3502.¹

The core principle of the LRA is simple: Agencies should design logging to enable necessary security outcomes and operational utilization rather than focus solely on compliance or tool enablement. Although tool capabilities are important, they should not dictate the initial approach; instead, agencies must prioritize operational needs. More specifically, operational needs should determine what the agency must collect, detect, investigate, reconstruct, and appropriately share, when authorized and within designated timeframes. A logging architecture that is optimized for ingestion volume, platform convenience, or retention in isolation may not adequately meet critical demands in the event of a real incident. For inquiries related to the LRA, please contact Logging@cisa.dhs.gov.

1.1 PURPOSE

The primary objective of the LRA is to provide Federal Civilian Executive Branch (FCEB) agencies with pragmatic, outcome-driven guidance for implementing logging, visibility, and operational standards and requirements set forth by Office of Management and Budget (OMB) Memorandum 26-14 (M-26-14): [Ensuring Effective and Efficient Agency Logging and Network Visibility to Defend Against Evolving Cyber Threats](#). The LRA converts federal policy directives into architectural, operational, and governance decisions required for logging capabilities that prioritize and enable continuous event monitoring, threat hunting, investigation, response, and forensics. M-26-14 requires agencies to submit an Agency Logging Plan to OMB and CISA within 90 days of the LRA’s publication. This Agency Logging Plan must describe the operational steps required for the agency to deploy and maintain effective continuous event monitoring (CEM) and threat-hunting, investigation, response, and forensics (THIRF) objectives. The plan should document the actions the agency will take to achieve the minimum baseline requirements defined in M-26-14. The plan should also document any additional log collection and activities that the agency conducts to achieve CEM and THIRF objectives, with consideration given to the agency’s threat environment, risk profile, and mission as provided in the LRA guidance. Each agency should periodically update its plan as necessary.

CISA hosts the LRA on the [Logging Reference Architecture](#) page on CISA.gov, where agencies can find the most current version. While CISA developed this version of the LRA to meet the requirements in M-26-14, future iterations will aim to expand on guidance deemed necessary and will prioritize development needs in partnership with agencies and the federal community.

¹ “44 United States Code (U.S.C.) § 3502: Definitions,” U.S. Government Publishing Office, 2024 Main Edition, effective January 14, 2019, [https://uscode.house.gov/view.xhtml?req=\(title:44%20section:3502%20edition:prelim\)](https://uscode.house.gov/view.xhtml?req=(title:44%20section:3502%20edition:prelim)).

The LRA enables agencies to develop, update, and maintain an Agency Logging Plan, as required and outlined in M-26-14. That plan documents an agency's implementation decisions for baseline and above-baseline logging, source coverage, dataflow, normalization, retention, integrity protections, access controls, validation, and improvement priorities. While M-26-14 establishes the minimum logging baselines and requirements agencies must achieve, the LRA provides a common reference guide to support agencies with decision-making and coherent documentation for strategic development of the Agency Logging Plan. As agencies continue to mature and advance those plans, the LRA will also evolve to support agencies' maturation.

The LRA does not replace the plan itself and is not a tool implementation manual, product selection guide, or vendor-specific schema. Instead, it clarifies what decisions are most significant for agencies to make by establishing three implementation rules:

1. The LRA exists to support delivery of federal outcomes, not to create a parallel architecture exercise.
2. Agency Logging Plans should document concrete decisions that trace back to those outcomes.
3. Compliance with policy is necessary but not sufficient; the logging capability must also be operationally usable when the agency needs it most.

The relationship between the LRA and federal logging policy, standards, and requirements must be explicit; policy informs the outcomes and minimum expectations to meet, while the LRA provides the architectural, data, control, and validation decisions to make to satisfy those requirements in practice. The LRA is not a restatement of M-26-14; it is the design and implementation reference that helps agencies convert policy into an Agency Logging Plan and operational capability.

1.2 BACKGROUND

CISA developed the LRA in response to M-26-14 and M-25-04: [Fiscal Year 2025 Guidance on Federal Information Security and Privacy Management Requirements](#) to support and enable FCEB agencies with a risk-based approach to implementing logging requirements. Executive Order (EO) 14028: [Improving the Nation's Cybersecurity](#), along with subsequent OMB memoranda M-22-09: [Moving the U.S. Government Toward Zero Trust Cybersecurity Principles](#) and M-21-31: [Improving the Federal Government's Investigative and Remediation Capabilities Related to Cybersecurity Incidents](#), initially and collectively emphasized the critical importance of robust logging capabilities within federal agencies. These directives required enhanced agency capacity for detecting, investigating, responding to, and remediating cyber incidents.

In response, M-26-14 specifically directed CISA to develop the LRA as comprehensive guidance for planning, implementing, and managing enterprise logging systems to facilitate continuous event monitoring, threat hunting, incident response, and digital forensic analysis. Moreover, M-26-14 establishes baseline logging requirements, provides flexible guidance to address emerging threats and technologies, and formally rescinds M-21-31.

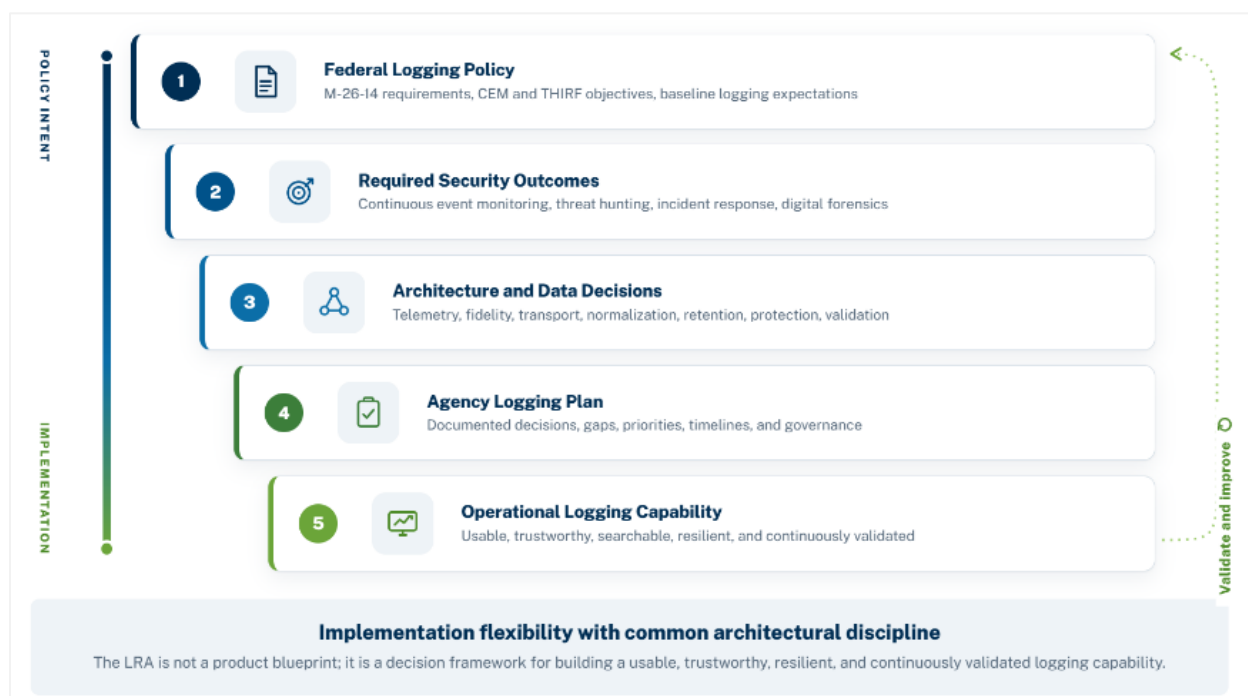


Figure 1: LRA Policy-to-Implementation Overview

The guidance in the LRA fully aligns with the requirements and objectives of M-26-14. The LRA includes references to M-21-31 to provide historical context and to acknowledge the significant progress agencies have already made in strengthening event logging, retention, and visibility. M-26-14 does not require agencies to start over; agencies should evaluate existing capabilities to determine whether they effectively support the enhanced CEM and THIRF objectives. Should agencies determine a need for updates or adjustments, the LRA offers guidance to support a smooth and informed transition from prior implementations to the expectations established under M-26-14.

The LRA also aligns to zero trust (ZT) principles, consistent with M-22-09, CISA's [Zero Trust Maturity Model \(ZTMM\) Version 2.0](#), and other federal ZT strategies and initiatives. It does not create additional ZT requirements but rather clarifies how agency logging capabilities should provide the visibility, evidence, and policy enforcement support needed to implement ZT principles across identity, devices, networks, applications, workloads, and data.

Building on these foundational directives, M-26-03: [President's Management Agenda](#) and M-26-14 recognize that federal agencies must defend against increasingly sophisticated cyber threat actors in a rapidly evolving threat landscape. The LRA functions as a strategic link between federal logging requirements and the design choices agencies must undertake to establish and maintain a robust enterprise logging capability that remains responsive to dynamic conditions. To address evolving threats, M-26-14 mandates an annual review of the LRA to determine whether enhancements, updates, or modifications are warranted. In accordance with the requirements set forth by M-25-04 Sec. III: *Establishment of an Interagency Enterprise Logging Working Group*, CISA will facilitate annual reviews in collaboration with the Chief Information Security Officer (CISO) Council Interagency Enterprise Logging Working Group to ensure a coordinated approach for updates. For inquiries or recommendations related to LRA updates, contact Logging@cisa.dhs.gov.

In addition to the guidance cited above, other authoritative federal and industry guidance on log management, cybersecurity risk management, and incident response informs the LRA. Notably, National Institute of Standards and Technology Special Publication (NIST SP) 800-61 Revision 3 (SP 800-61 Rev. 3): [Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A Cybersecurity Framework \(CSF\) 2.0 Community Profile](#) frames incident response as an integrated element of cybersecurity risk management, emphasizing that enterprise logging must do more than generate alerts. It must enable prioritization, scoping, containment, recovery, and continuous improvement across the incident-response life cycle. Complementary guidance and industry best practices further reinforce the need for planning, pipeline observability, normalization, reliable transport, and operationally sustainable architectures. Together, these resources underscore that strong logging depends on trustworthy telemetry collection, consistent timestamps, contextual metadata, process coordination, and search mechanisms that support near-real-time monitoring and historical investigation as environments evolve.

EO 14409 [Promoting Advanced Artificial Intelligence Innovation and Security](#) and other recent federal directives emphasize the need for rapid integration of artificial intelligence (AI) capabilities — including machine learning (ML), and large language models (LLM) — that enhance security operations within governed, risk-managed frameworks. When used within the logging infrastructure, AI/ML can improve detection, correlation, triage, prioritization, hunting, and investigation across large volumes of telemetry data. Strong governance and operational hygiene processes help ensure that agencies utilize AI-assisted outputs ethically to enhance security operations, without replacing required source fidelity, operator judgment, or accountability for security decisions. Consistent with OMB M-25-21 [Accelerating Federal Use of AI through Innovation, Governance, and Public Trust](#), agencies must inventory, assess, monitor, and document high-impact AI use cases, and aim to ensure that AI-enabled analytic techniques adhere to defined safeguards, transparency requirements, and accountability standards. M-25-21 describes “high-impact AI” as AI that could have significant impacts when deployed. Consistent with federal AI governance expectations outlined in M-25-21, agencies should treat AI/ML capabilities used within logging pipelines as managed information assets and/or systems subject to the same oversight, validation, and security controls as other enterprise technologies.

1.3 SCOPE

The LRA presents prescriptive recommendations to guide agencies through critical logging decisions to meet federal requirements, emphasizing conditions necessary for integrity and operational utility while supporting flexibility where appropriate. It applies to enterprise logging capabilities across FCEB agencies.

1.3.1 In Scope

The LRA covers the following areas:

- **Logging coverage, fidelity, and architectural decisions** across identity, endpoint, network, applications, cloud (software-as-a-service [SaaS], platform-as-a-service [PaaS], infrastructure-as-a-service [IaaS]), internet of things (IoT), operational technology (OT), administrative, and data/object activities and controls.
- **Enterprise logging infrastructure**, including how agencies collect, transport, normalize, store, retain, access, protect, and validate data.
- **Operational use cases** for achieving CEM, THIRF, and other technical requirements for developing and maintaining Agency Logging Plans. These use cases include logging in traditional IT, cloud environments, IoT systems, mission systems, high value assets (HVAs), and specialized or segmented environments.
- **Safeguarding the logging infrastructure** as a mission-critical capability.

- **Advancing logging capabilities** from fragmented or compliance-driven practices toward an operationally mature enterprise capability.
- **Systems operated on behalf of the agency**, including contractor-run, managed service provider (MSP), or third-party environments that support information system functions. Agencies must ensure logging, retention, and visibility decisions also apply to these delegated or externally operated systems.

1.3.2 Out of Scope

The LRA does not:

- **Prescribe specific vendor schemas, products, platforms, operating models, or commercial architectures.**
- **Define mandatory technical stacks or operational workflows that agencies must use.**
- **Replace policy or create new compliance requirements outside the scope of M-26-14.**
- **Expand CISA's responsibilities beyond what is authorized under M-26-14 or other applicable directives or statutes.**
- **Require above-baseline logging elements.** Where the LRA describes above-baseline elements—such as additional data or object-activity types that improve CEM or THIRF—these represent operational best practices. Agencies may adopt them based on mission risk, but they are not required under M-26-14.

2. HOW TO USE THE LRA

Agencies should use the LRA to develop, update, and validate enterprise logging capabilities that guide the development and maintenance of governable Agency Logging Plans. Sections 1 and 3 establish the policy framework and outline the security and operational outcomes the agency must enable. Sections 4 and 5 describe the architectural principles that support logging capabilities that are timely, usable, resilient, and governable in practice. Sections 6 – 10 address the Agency Logging Plan objectives, including sustainable maturation of logging capabilities over time, protection of the logging infrastructure, and baseline or above-baseline coverage, fidelity, schema, and interoperability practices.

Agencies may tailor their approach for enabling logging capabilities to the unique realities of their own environments, but they must still adhere to the essential architectural requirements that ensure logging is both effective and reliable.

The LRA supports agencies with strategic decision-making in coordination with operational functions that are integral to an agency and their mission. At a practical level, agencies should use this document to answer five questions:

1. What security outcomes must the logging capability support?
2. What data must my agency collect and retain to support those outcomes?
3. How should that data move through the logging infrastructure from collection through analysis and storage?
4. What controls must my agency put in place to protect the logging capability and govern access, retention, and authorized sharing?
5. How will my agency validate that the logging capability is complete, usable, and aligns to policy?

Effective use of the LRA requires cross-functional coordination and an understanding of operational dependencies and interconnectivity. While architecture is the primary focus, the scope also includes design decisions, engineering tradeoffs, and governance, as well as operational choices about how to collect, normalize, store, retain, access, and share data. These decisions may directly affect monitoring operations, incident response, privacy, records management, acquisition, and security governance and should therefore be approached as a shared operational capability rather than as an isolated toolset.

This perspective aligns with NIST SP 800-61 Rev. 3, which treats incident response as part of enterprise cybersecurity risk management, emphasizing that roles across the organization contribute to effective response and recovery. Where agencies use AI, such as LLM- or ML-enabled analytics as part of the logging capability, the logging plan should identify the intended security use cases, data inputs those methods rely on, decisions those methods may inform, validation and performance measures used to assess them, human review points required for consequential actions, and fallback operating mode if the AI-assisted capability is degraded, unavailable, or producing unreliable results.

2.1 INTENDED AUDIENCE

The actionable guidance in the LRA is primarily for agency enterprise architects, security architects, and engineering leads responsible for designing and evolving agency logging capabilities. However, CISA developed the LRA for all federal teams involved in the decision-making and implementation of agency technical operations, including executive leadership, program stakeholders, and technical personnel. Additionally, the intent of the LRA is to support security operations center (SOC) engineering teams, platform operators, incident response leaders, and program stakeholders responsible for writing, reviewing, or approving the Agency Logging Plan.

2.2 RECOMMENDED USE CASES

The LRA will serve as guidance for meeting baseline requirements through various operational approaches. CISA advises agencies to refer to this document for the following scenarios:

1. **To build or redesign an enterprise, federated, or shared logging architecture.**
Start with Section 3 to establish required outcomes, then move into the architectural decision sections before finalizing coverage, fidelity, and plan structure.
2. **To update an existing logging infrastructure to align with federal expectations.**
Start with the policy and transition context, then use Section 6 for baseline coverage and fidelity, and Appendix E for validation and to identify where prior logging work carries forward and where it does not.
3. **To validate or update an existing Agency Logging Plan.**
Use Section 3 to determine whether the plan is specific enough to support implementation and whether the current capability is usable in practice.
4. **To prioritize logging capability improvements for a maturing agency.**
Leverage the Section 9 above-baseline analysis and the Section 11 maturity progression objectives to identify the most important decisions, such as closing critical coverage gaps, increasing fidelity for high-value datasets, improving enterprise visibility, strengthening integrity and resilience, and validating usability over time.
5. **To support the governance of AI when used to enhance logging capability.**
Use the LRA to inform agency decisions on integrating AI into logging processes in ways that enhance operational value while preserving required governance and oversight. Discuss using AI to enhance productivity of continuous event monitoring and THIRF lifecycles.

3. SECURITY OUTCOMES

M-26-14 establishes two priority objectives that agency logging capabilities must enable:

1. **CEM:** Logs, log management, and logging infrastructure that enable agencies to monitor network activity in real time, promptly flag anomalous activity, and respond to that activity in a timely manner. These logs are typically ingested and monitored by a SOC. In addition to event logs, and in accordance with M-26-14,² the scope of continuous event monitoring also includes the ability to monitor and use hardware asset management (HWAM) and software asset management (SWAM) data, including capabilities provided by the [Continuous Diagnostics and Mitigation \(CDM\) Program](#), to determine whether log coverage encompasses all IT in agency environments.
2. **THIRF:** Logs, log management, and logging infrastructure that enable agencies to investigate and perform forensic analysis of network activity after a known or suspected compromise with the purpose of mitigating, remediating, and recovering from threat actor activity. To enable THIRF, agencies must maintain sufficient [actively searchable] and [retrievable] storage as well as the capability to retrieve and centralize logging data from multiple sources to map attack patterns.

From a practical implementation standpoint, the LRA decomposes THIRF into three operational functions that are treated as interconnected operational demands of one logging capability, not as isolated tools or data strategies. This approach focuses on core operational capabilities agencies must build to achieve the objectives of THIRF and CEM in practice. As such, agencies should design logging capabilities to support:

1. CEM
2. Threat hunting as a THIRF activity
3. Incident response as a THIRF activity
4. Digital forensics as a THIRF activity

Across all outcomes, agency logging should align with ZT principles, supporting continuous verification of users, devices, services, workloads, and data access decisions. Continuous monitoring depends on timely and usable telemetry. Threat hunting depends on the ability to search and correlate historical and current data across sources. Incident response depends on rapid scoping, trustworthy records, and access to enough context to make containment and eradication decisions. Digital forensics depends on preservation, integrity, provenance as the verifiable record of the data source/ownership/modifications, and ability to reconstruct an incident. The LRA also considers the CDM Program's Manage Events (MNGEVT), a capability offered within the Network Security Management program area, as a federal design input for event monitoring, incident response, audit and accountability, privacy, contingency planning, endpoint detection and response (EDR), and related logging architecture decisions.³

²"M-26-14: Ensuring Effective and Efficient Agency Logging and Network Visibility to Defend Against Evolving Cyber Threats," Executive Office of the President and Office of Management and Budget, effective May 22, 2026, <https://www.whitehouse.gov/wp-content/uploads/2026/05/M-26-14-Ensuring-Effective-and-Efficient-Agency-Logging-and-Network-Visibility-to-Defend-Against-Evolving-Cyber-Threats.pdf>.

³ "CDM Program Overview," CDM Program, Cybersecurity and Infrastructure Security Agency, https://www.cisa.gov/sites/default/files/publications/2020%252009%252003_CDM%2520Program%2520Overview_Fact%2520Sheet.pdf.

3.1 CONTINUOUS EVENT MONITORING

CEM provides ongoing visibility needed to detect suspicious or anomalous activity, assess the security state of the environment, and ascertain conditions that require investigation or response. For purposes of this LRA, includes more than data collection; it also includes the timeliness, context, and analytic handling needed to convert telemetry into usable signals for operational teams. A logging capability that supports continuous event monitoring should allow the agency to answer the following, within cyber relevant timeframes:

- Is suspicious or anomalous activity occurring across identity, endpoint, network, cloud, IoT, application/service, and administrative domains?
- Are security tool alerts generated with enough context and timeliness to support triage and follow-on investigation?
- Are known indicators of compromise (IOCs) present in current or recent telemetry?

These are operational questions, not abstract goals. If these questions cannot be answered because telemetry arrived too late, data is too isolated or decentralized, key fields are missing, source coverage is uneven, or event handling strips away necessary context, then the logging capability does not fully support continuous event monitoring regardless of how much data is technically ingested. To assess the security state of the environment and validate whether CEM capabilities provide sufficient visibility, agencies should measure monitoring coverage against a standardized adversary-behavior framework, such as [MITRE Adversarial Tactics, Techniques, and Common Knowledge \(ATT&CK®\)](#). ATT&CK-aligned mappings enable agencies to understand how well current detection capabilities address relevant adversary tactics, techniques, and procedures (TTPs); identify telemetry and visibility gaps; evaluate monitoring maturity; and prioritize development of new detections based on operational risk and criticality of adversary behaviors. Therefore, acceptable latency and timeliness expectations should be explicitly defined in the Agency Logging Plan and tied to monitoring and response objectives.⁴

NIST SP 800-61 Rev. 3 reinforces this outcome-oriented view, emphasizing that modern incident response depends on detection functions that find and analyze possible attacks or compromises. Therefore, organizations should integrate incident response broadly across cybersecurity risk management rather than as an isolated technical function. For enterprise logging, that means continuous monitoring should be designed to feed decision-making and response functionality, not just dashboards.

3.2 THREAT HUNTING

Threat hunting is a proactive, hypothesis-driven search for adversary behavior that evades existing detections by utilizing search, correlation, and reconstruction capabilities across time and sources. Its purpose is to shorten dwell time, find weak signals that automated logic may miss, and improve the agency's ability to convert discovered patterns into stronger detections and better defensive controls. A logging infrastructure that supports threat hunting should allow the agency to answer the following questions, within its searchable operational window:

- Can analysts search and correlate normalized and source-detailed data across identity, endpoint, network, cloud, IoT, and application/services sources?
- Are sufficiently detailed fields available for investigation, such as command-line arguments, parent-child process relationships, authentication context, and cloud application programming interface (API) request details?
- Do consistent identity and asset identifiers exist across sources to support pivot-based investigation?

⁴ The LRA does not prescribe baseline expectations for acceptable latency and timeliness periods as agencies should independently set organization-defined frequencies in consideration of risk tolerance and operational capabilities. However, the general standard is to aim for real-time or near real-time monitoring and response.

The outcomes to these questions and relevant capabilities have direct implications for data design. While storing the data is a key component for effective threat hunting, the search also depends on adequate query performance and analyst usability across relevant time windows. To support these objectives, relevant datasets should remain searchable, normalized records should preserve common fields for cross-source pivots, and source-native detail must remain retrievable when an analyst needs to go deeper.^{5, 6}

Threat hunting also benefits from NIST's broader incident response guidance within SP 800-61 Rev. 3, especially the emphasis on cyber threat intelligence, cross-source analysis, and continuous improvement. The point of hunting is to ascertain individual incidents, while also identifying patterns, refining detections, and improving the surrounding risk-management system. Agencies should therefore view hunt-ready data as a deliberate design objective, not as a side effect of retention.

AI-assisted techniques can also support threat hunt through the identification of weak signals, proposing pivots, summarizing large query results, or by highlighting candidate relationships across entities and time. However, these techniques should augment, rather than replace, analyst-driven hypotheses and access to authoritative raw and normalized records.

3.3 INCIDENT RESPONSE

Incident response is the coordinated set of activities used to detect, analyze, contain, eradicate, and recover from incidents. A logging capability supports incident response when it helps responders scope an incident accurately, move quickly enough to affect outcomes, and preserve the information needed to justify and document their actions. In practice, this means logging must support both the speed needed to contain the incident and the confidence that the scope and timeline are grounded in reliable evidence. A logging capability should allow the agency to answer the following questions within timeframes that matter to containment and recovery:

- Which systems, accounts, identities, and/or data are affected?
- Can analysts reconstruct user and process timelines from correlated logs?
- Are records integrity-protected and handled in a way that supports evidentiary use where required?

NIST SP 800-61 Rev. 3 emphasizes that incident response now operates within a broad, continuous cybersecurity risk-management context, highlighting the importance of prioritization, incident analysis, scope estimation, coordination, documentation, and preservation of incident data and metadata with integrity and provenance. As such, agencies should design logging so that responders can move from alert to correlated datasets quickly, estimate magnitude with increasing confidence, preserve records and actions occurring during investigation, and document lessons learned in ways that improve future performance. If applicable to logging architecture and if agencies can do so, CISA recommends configuring this capability into the security information and event management (SIEM) to enable direct pivots to EDR and investigative dashboards that correlate telemetry and provide additional context. During incident response, AI-assisted techniques can support triage, scoping, timeline reconstruction, and summarization, but actions with material operational, legal, or privacy consequences should remain subject to human review and established incident criteria.

⁵ M-26-14 describes “actively searchable” as data that can be immediately used for cyber defense, and detections and analytics can be applied to the data without requiring additional steps related to preparation of the data.

⁶ M-26-14 describes “retrievable” as data that can be used for cyber defense activities after one or more intermediary steps to prepare the data, including actions that may be required to replay data from long-term storage in an analytics tool, such as moving the data from an archive into real-time analysis platforms, or “thawing” data in cold storage for access in a faster storage tier.

From the LRA perspective, this means agencies should treat incident response support as a design test for logging fidelity and usability. It is not enough for security tools to generate alerts. The agency must also be able to pivot from those alerts into relevant identity, endpoint, network, cloud, and administrative records; correlate them with enough confidence to reconstruct what happened; and access preserved records quickly enough to support containment, eradication, and recovery decisions. Logging should provide the context needed to support timely containment, eradication, and recovery. These capabilities can be enabled through security orchestration, automation and response (SOAR) and centralized within a SIEM to rapidly enable them for coordinated incident handling.

3.4 DIGITAL FORENSICS

Digital forensics supports root-cause analysis, impact assessment, accountability, and legal or administrative proceedings when applicable. A logging capability supports digital forensics when it allows investigators to reconstruct what occurred with high confidence using records that are complete enough, preserved long enough, and protected well enough to be trusted. This is where integrity and provenance requirements become especially important for trustworthy reconstruction, defensible agency decision-making. They should not be treated as concerns only for post-incident legal processes.

A logging capability that supports digital forensics should allow the agency to answer, within the retrievable retention window:

- Can investigators reconstruct the sequence of events, including initial access, escalation, lateral movement, and data impact?
- Are designated datasets protected in ways that support evidentiary use, such as hashing, signing, or immutability where required?
- Are acquisition and handling procedures documented, and are duties appropriately separated where evidentiary handling is required?

This outcome also depends on the preservation of supporting context. Asset inventories, ownership information, network-flow representations, configuration baselines, and related reference data often determine whether an event record is merely present or genuinely interpretable during a forensic review. NIST SP 800-61 Rev. 3 reinforces this by highlighting the value of current asset inventories, data inventories, and incident records that preserve integrity and provenance. Agencies should therefore avoid treating forensics as a storage-only problem, as the issue could also stem from data design, context preservation, and handling.

Additionally, AI-assisted capabilities support triage, pattern discovery, or prioritization of large datasets, but they should not alter source evidence, replace chain-of-custody controls, or be treated as a substitute for authoritative records and reproducible forensic methods.

3.5 MEASURING LOGGING CAPABILITY READINESS

Agencies should assess logging readiness using outcome-oriented measures. A mature capability is not defined by the number of connectors, collectors, or products deployed. It is defined by whether the agency can use its logging capability to monitor, hunt, respond, and reconstruct activity with acceptable speed and confidence. These outcome-oriented measures are designed to complement—and directly map to—the maturity model defined in M-26-14, Appendix C, and are further elaborated on in Section 11 of the LRA. By linking operational readiness metrics to maturity model elements, agencies can align their measurement and improvement efforts with both federal expectations and practical implementation. At a minimum, agencies should measure:

- **Cost:** Consideration and analysis of costs (including labor, staff burden, operations, maintenance, procurement, licensing, and service costs) pertaining to log sources and collection, in relation to its impact on the agency's cybersecurity risk. Although this LRA version focuses on cost related to storage and architecture, agencies should consider other relevant cost elements. Are there mitigations in place, or other log sources that are already in place that make collection of that data less impactful? What is the degree of impact the system has on the agency's mission? Are there alternative infrastructure or design choices that achieve mission and operational goals while decreasing cost or complexity for operability?
- **Coverage:** Are required log sources across all environments represented? Does collected telemetry sufficiently depict network and host activity? Are evaluations conducted to identify logging gaps and overlap? Agencies should determine which sources offer the most meaningful visibility in consideration of their mission, risk profile, operational capabilities, and relative environments, rather than assume every possible dataset must be collected.
- **Timeliness:** Are events available quickly enough to support the intended outcome?
- **Fidelity:** Do event records contain the fields and context required for correlation, scoping, and reconstruction?
- **Integrity:** Have logs or other data collected been altered or manipulated in any way outside of planned data engineering for log collection, ingestion, and normalization?
- **Searchability and retrievability:** Can analysts search and retrieve data within the expected windows?
- **Data quality:** Are timestamps reliable, required fields populated, mappings stable, and parser failures visible?
- **Operational usability:** Can analysts perform expected pivots and investigations without excessive manual reconciliation? Are there attributes (such as timestamps) that are available that allow for correlation between events from the same and different log sources?
- **Forensic readiness:** Are designated datasets protected and handled appropriately for evidentiary use where needed?
- **Validation maturity:** Does the agency actively test whether the capability is complete, usable, and resilient over time?

Report these measures at operational and executive levels to feed a continuous improvement loop. NIST SP 800-61 Rev. 3's emphasis on integrating lessons learned, evaluating incident-response performance, and improving plans and procedures over time is directly relevant here: logging readiness should be treated as something the agency validates and improves continuously, not something it declares once.

4. ARCHITECTURAL DECISIONS

This section defines the architectural outcomes, constraints, and design considerations agencies must account for when building logging infrastructure and capabilities that support federal security objectives and policy requirements. The LRA provides agencies with implementation flexibility while requiring them to meet the core conditions that make logging operationally effective. This flexibility allows agencies to make informed, risk-based decisions about what telemetry to collect, retain, and analyze—based on their mission, environment, and operational security requirements—rather than prescribing a single implementation approach. By preserving agency autonomy, the LRA enables teams to select implementation paths that remain understandable, appropriately scoped, and sustainable, avoiding unnecessary complexity that could undermine long-term operability, continuity, and clarity across diverse environments.

The principles that follow are intended to guide architecture and engineering decisions across collection, transport, processing, storage, protection, and sharing. Together, they describe what a sound logging architecture should achieve, and the conditions agencies need to account for as they design, operate, and evolve that capability over time. It is important to note that AI/ML and AI/LLM are implementation options, not architectural objectives. Agencies should adopt them only where they measurably improve required security outcomes and with effective governance and oversight processes in place.

4.1 TELEMETRY DECISIONS

An agency's first architectural decision is informed through identifying the specific telemetry it must collect to support required security outcomes. In determining this, an agency should be guided by the outcomes defined in Section 3 and the baseline logging requirements established by Appendix B of M-26-14, rather than by what is currently available on a platform or what is easiest to integrate. The goal is not to ingest as much as possible, but to be able to answer the operational questions that matter for monitoring, threat hunting, incident response, and forensics.

M-26-14 requires that baseline telemetry must support required CEM and THIRF activities. Agencies should identify which categories of data are essential, what fidelity is required, and where current gaps most affect operational outcomes.⁷

Agencies should identify the telemetry categories that provide the minimum usable data foundation across identity, endpoint, network, cloud, IoT, applications/services administrative, and resource or data activity. Logging source coverage alone is not enough, as a source can technically be onboarded but still be operationally weak when key fields are missing, delivery is delayed, timestamps are unreliable, or the source produces only summarized or heavily filtered outputs that do not support correlation and reconstruction. Agencies should decide which source types are in scope and specify the minimum event fidelity each category must preserve. A maturing agency should document these decisions in practical terms using the following considerations:

- What telemetry categories are required to support baseline outcomes?
- What systems, services, and environments are expected to generate them?
- What event fidelity is required for the data to be operationally usable?
- What gaps exist today, and which are most urgent to close?

These decisions form the basis for later decisions about transport, normalization, storage, retention, access, and validation. Agencies should not treat them as a simple inventory task. They establish the foundation for the agency's operational logging architecture.

⁷ "M-26-14, App. B, Req.: Ensuring Effective and Efficient Agency Logging and Network Visibility to Defend Against Evolving Cyber Threats," Executive Office of the President and Office of Management and Budget, effective May 22, 2026, <https://www.whitehouse.gov/wp-content/uploads/2026/05/M-26-14-Ensuring-Effective-and-Efficient-Agency-Logging-and-Network-Visibility-to-Defend-Against-Evolving-Cyber-Threats.pdf>.

4.2 COLLECTION DECISIONS

Agencies should collect security-relevant events as close to the authoritative source as practical and preserve provenance throughout the logging infrastructure. **This is a key design constraint covered by the LRA.** Logging loses value quickly when an agency cannot trust where a record came from, when it was generated, how it was handled, or what transformations were applied before it became visible to operators. Therefore, agencies should avoid relying solely on processed, summarized, or downstream log sources. Authoritative records from the originating system are often necessary for attribution, reconstruction, and evidentiary use.

In practice, this means agencies should prefer authoritative log sources over derived or partially processed copies when doing so materially improves accuracy, attribution, and investigative value. For example, native control-planes or administrative audit records are usually more authoritative than downstream summaries generated by another platform. The same logic applies to records that identify privileged changes, authentication outcomes, or resource activity. Derived outputs can still be useful operationally, but they should not become the agency's only durable representation of important events. Ensuring AI-derived annotations, scores, summaries, or recommendations remain traceable to the source records, model version, and processing context that produced them is an important element to consider.

Preserving provenance also means preserving enough metadata to understand how a record entered the logging infrastructure. At a minimum, agencies should be able to identify the originating system or service, the event time, the collection path, and any meaningful transformation or enrichment that occurred. Without that, it becomes harder to resolve discrepancies, validate completeness, or defend analytic conclusions during an incident.

Collection design should address interruption considerations, including buffering, persistent restart, retry mechanisms, and verification of successful delivery—these are fundamental operational requirements rather than optional features. These decisions should support the preservation of trust in the capability. If an outage or pipeline failure can silently drop important data, then the logging capability is not sufficiently reliable for mature incident operations. Agencies should therefore document where collection occurs, what authoritative source each collection path relies on, how provenance is preserved, and how the design detects or compensates for missed delivery.

4.3 TELEMETRY TRANSPORTATION

Agencies should move telemetry through the logging infrastructure using transport patterns that support timeliness, encryption, resilience, replay, and change over time.⁸ While direct point-to-point (or tightly coupled) integrations between every producer and every consumer may work in certain cases, they are not a sound enterprise default—they may become brittle, hard to govern, and difficult to validate as the number of sources and consumers grows. Durable, decoupled transport is generally a stronger long-term pattern.

Where the security outcome depends on timeliness, agencies should generally prefer event-driven delivery. This includes native export, streaming, brokered forwarding, and similar mechanisms that support low-latency handoff. Event-driven delivery is especially important for telemetry used in CEM and early incident detection. Polling remains valid where a source only exposes logs through APIs, scheduled export, or similar mechanisms, but agencies should treat it as a bounded secondary pattern, that is, it should be used only in situations where direct, event-driven delivery is not feasible due to technical or operational constraints. “Bounded” means that pulling is intentionally limited in scope and frequency and is not relied upon as the primary collection method of security-relevant telemetry. Agencies should establish clear criteria for when polling is appropriate, monitor its effectiveness, and ensure it does not inadvertently become the default approach for sources where real- or near-real-time delivery is critical for operational outcomes.

⁸ Change over time refers to sequential updates, state transitions, configuration modification, or behavioral shifts as they occur.

Transport design should also explicitly address:

- Durable handoff
- Buffering
- Checkpointing
- Replay
- Encryption
- Back pressure
- Partial failure
- Monitoring of queue or transport health

These conditions allow the architecture to absorb outages and recover missed data without rebuilding log collection from scratch. They are also part of what makes the capability governable over time. If the architecture cannot tolerate downstream outages or detect when a path has degraded, then the agency will often discover failures only when analysts cannot find the data they expected during an incident.

For constrained, segmented, remote, OT, or IoT environments, local buffering or store-and-forward patterns may be necessary (see Section 6.2.9 for further IoT/OT transport expectations). Agencies should not force low-latency collection methods that create operational instability in those environments. The baseline expectations for provenance, timestamp accuracy, integrity, and validation still apply. The environment may justify a different transport path, but it does not eliminate the need for trustworthiness.

4.4 NORMALIZATION, ENRICHMENT, AND SCHEMA ENFORCEMENT

Agencies should maintain a usable normalized representation of key security-relevant events in the logging infrastructure. Normalization will occur at ingestion, in shared downstream processing, or through another durable stage. Normalization should improve usability—not eliminate meaningful source context. Over-flattened or over-abstracted records impede investigation and reduce trust during incidents. It is critical that operators and analysts can work across identity, endpoint, network, cloud, IoT, application/services, and administrative sources using a good-enough representation to support detection, threat hunting, investigation, and reporting. Leaving those operations dependent on dozens of incompatible proprietary source formats is difficult to sustain and slower to use during active incidents. Where AI-assisted enrichment is used, agencies should distinguish source-provided data from inferred or model-generated context so operators can understand what is authoritative and what is derived.

At the same time, agencies should not treat data normalization as flattening every event into the lowest common denominator. Over-flattened data is viable to support dashboards and basic counts but often weakens triage, scoping, and reconstruction. Normalization is a means of improving operational usability, not a license to destroy the source meaning that analysts need during deeper review. Agencies should therefore make explicit decisions that consider:

- Where events in logs are normalized in the infrastructure
- What fields are required to use common names/schemas relative to data types and for cross-source operations
- What source-native context remains available after the normalization
- Where enrichment occurs, including adding meta fields to add contextual information about logs or events

- Where authoritative information is maintained and utilized for normalization processes, including reference values for identifying codes in event logs and ensuring consistency of subcomponent names (where relevant)
- How source format changes are governed and validated
- Which open-source cybersecurity schemas can be utilized for normalization⁹

Enrichment should improve clarity, not obscure original meaning. Identity, asset, and configuration context can materially improve monitoring and triage when added from authoritative sources, but operators should still be able to distinguish source-provided values from added context when necessary. This becomes especially important in incident response and forensics, where misattribution or hidden transformations can undermine confidence in the data.

Agencies should also distinguish between event normalization and workflow-specific payload reduction. A case record, alert object, or SOAR ticket may only need a subset of event fields, which is not the same as the durable normalized event record needed for cross-source search and investigation. Agencies should avoid letting downstream workflow objects become the only durable representation of security events if they still depend on broader security analytics.

4.5 SEARCHABLE, RETRIEVABLE, AND IMMUTABLE HANDLING

Agencies should make an explicit distinction between searchable operational data, retrievable retained data, and designated immutable or evidentiary datasets. **This is one of the most important storage decisions covered by the LRA.** Retention alone is not enough if the right data cannot be searched within the time window required for monitoring, threat hunting, and routine investigation. Conversely, keeping all telemetry in high-cost, long-term operational storage is often unnecessary and unsustainable. Not all telemetry must remain in the SIEM, but it should remain retrievable within operationally acceptable timeframes. Retention strategies should balance cost, performance, and operational needs while ensuring critical evidence remains available for investigations and digital forensics. The selected architectural design should intentionally support immediate operational use and long-term retrieval needs.

Actively searchable operational data should include datasets the agency depends on for continuous monitoring, threat hunting, triage, and common incident-response pivots. These datasets should remain in storage tiers that support low-latency search over the required operational window. Retrievable retained data may be moved into lower-cost storage earlier, if the agency can still retrieve it within the timeframes needed for reconstruction, review, and oversight. Designated evidentiary datasets will require separate handling such as immutability, stronger access controls, and more rigorous auditability.

Agencies should tie these operational decisions directly to outcomes and not to vendor defaults, and with consideration of the following:

- What datasets drive routine monitoring and hunting?
- How long must the datasets remain actively searchable?
- What datasets are eligible for earlier transition to lower-cost retrievable tiers?
- What datasets require immutable handling and for how long?
- How will retrieval, integrity, and auditability be validated?

⁹ Examples of validated, open source cybersecurity schemas include the Open Cybersecurity Schema Framework ([OCSE](#)), Elastic Common Schema ([ECS](#)), Structured Threat Information Expression ([STIX](#)) and Trusted Automated Exchange of Intelligence Information ([TAXII](#)), and any other validated source eligible for federal use.

These choices should appear in the Agency Logging Plan in explicit, plain language, allowing cost management to become a legitimate architectural input rather than a downstream storage exercise. These decisions should align storage and tiering to actual operational use that preserves required retention, retrievability, and trust.

4.6 POLICY ENFORCEMENT

Agencies should treat logging as part of policy enforcement, not only as a record of events after the fact. Where access authorization, segmentation, conditional access, device posture, or data handling decisions are made, the logging architecture should preserve the decision context, outcome, and authoritative sources so agencies can validate that zero trust policies are operating as intended.

Agencies should apply minimization, tagging, segmentation, redaction, routing, access control, and outbound sharing decisions through a controlled policy enforcement point rather than unintentionally siloing those decisions across source integrations or downstream consumers. This is a durable architectural pattern because the same dataset may need to support multiple purposes at the same time, such as internal analytics, longer-term retention, restricted access for sensitive content, and authorized sharing in a reduced or tagged form. Embedding policy logic separately into every source path or downstream tool makes operational consistency and change management more complex.

The policy enforcement point should generally sit after the data can be classified, normalized, enriched, and validated, but before it crosses agency-controlled boundaries or enters restricted analytical contexts. In practice, agencies should decide where:

- Sensitive fields are segmented or masked
- Different user populations receive different levels of access
- Outbound sharing is reduced, tagged, or transformed
- Auditability is applied to privileged access and sharing decisions
- Changes to policy logic are governed

This design matters for both security and operational functions. Overly fragmented policy enforcement leads to inconsistent outcomes and brittle exception handling. Overly centralized policy enforcement without enough context leads to incorrect reduction or routing. Agencies should therefore design policy enforcement as a deliberate function of the logging architecture, not as an afterthought attached to individual tools.

4.7 LOGGING CAPABILITY OBSERVATION, VALIDATION, AND SAFE CHANGES

The logging capability should be designed with robust mechanisms to identify when capabilities or operational functions are not operating as intended. This requirement exceeds merely monitoring infrastructure health; agencies must be able to detect coverage gaps, delivery failures, latency deviations, parser and schema inconsistencies, missing data fields, sharing anomalies, and other issues that may compromise data integrity even when systems appear to be functioning as intended. To address these needs, agencies should incorporate features such as:

- Health and completeness monitoring
- Schema conformance checks
- Required-field validation
- Synthetic tests
- Replay or backfill validation where appropriate
- Controlled rollout and rollback
- Clear visibility into where failures occur in the pipeline
- Automated threat emulation

A logging capability that lacks validation of operational functions cannot be considered reliable. This becomes especially important as sources, interfaces, platforms, and policies evolve over time. The architecture must facilitate safe transition and avoid making assumptions about change. This includes clearly defining ownership of onboarding standards, ensuring timely updates to parsers and mappings, maintaining awareness of dependencies, and establishing rollback procedures to address operational issues or degradation arising from changes.

For the Agency Logging Plan, two questions should be addressed: How will the agency know that required datasets are present, timely, complete, and usable for the outcomes they are intended to support, and how will the agency detect and recover from degradation over time? If the plan cannot answer these questions clearly, the logging capability is not yet designed at a mature level.

5. OPERATING MODEL AND DATAFLOW PATTERNS

This section translates the architectural decisions described in Section 4 into practical operating models and dataflow patterns agencies can use to build or modernize their enterprise logging capability. Its purpose is to show how telemetry can move through the logging infrastructure in ways that support required outcomes while preserving flexibility where mission, environment, and operating model legitimately differ. This section does not catalog every possible architecture but intends to provide recommended architectural options.

Section 5.1 introduces a recommended default operating model for a maturing federal agency, followed by descriptions of common collection, transport, processing, storage, and access patterns. Subsections 5.2 to 5.5 summarize common architectural patterns neutrally, with notes on use cases and tradeoffs.

M-26-14 states that required logs must be readily available to the agency's top-level SOC, even when storage is decentralized or federated. Architectures must support enterprise-wide visibility.¹⁰

5.1 RECOMMENDED DEFAULT OPERATING MODEL

M-26-14 encourages agencies to evaluate different approaches to make logs available to the top-level agency SOC for the enablement of CEM and THIRF objectives. Agencies may centralize log storage, provide centralized access to distributed logs, or use a hybrid model that combines centralized storage for some datasets with federated access to others. For most maturing agencies, the strongest default operating model is source-appropriate collection with common downstream handling. Under this model, telemetry is collected using methods appropriate for the source and environment, then moved through reliable transport into shared downstream processing and storage functions where it can be normalized, enriched, validated, protected, and made available for operational use. The agency does not need one collection method for every source, but it should aim for a more common approach once the data enters the overarching logging infrastructure.

This default operating model has several advantages for a maturing agency. First, it avoids forcing all environments into one collection pattern even when they differ materially in capability, connectivity, or risk. Second, it reduces the long-term cost and fragility of letting every source evolve its own isolated ingestion path, schema handling, and routing logic. Third, it gives the enterprise SOC or equivalent operational function a better chance of maintaining usable visibility across domains without requiring every team to operate independently. Lastly, it creates a natural place for shared validation, normalization, enrichment, policy enforcement, and tiered retention. In practical terms, this default operating model usually includes:

¹⁰ "M-26-14, App. B, Req. 2: Ensuring Effective and Efficient Agency Logging and Network Visibility to Defend Against Evolving Cyber Threats," Executive Office of the President and Office of Management and Budget, effective May 22, 2026, <https://www.whitehouse.gov/wp-content/uploads/2026/05/M-26-14-Ensuring-Effective-and-Efficient-Agency-Logging-and-Network-Visibility-to-Defend-Against-Evolving-Cyber-Threats.pdf>.

- Collection close to the source
- Durable transport with buffering and replay characteristics
- Shared or coordinated normalization and enrichment
- Operational search tiers for monitoring, triage, and threat hunting
- Retrievable lower-cost retention tiers
- Enterprise visibility for the top-level SOC
- Controlled policy enforcement before data crosses boundaries or enters restricted sharing paths

This model does not require a single physical architecture or a single product. It does require convergence on the agency's handling model so that disparate telemetry becomes useful as one enterprise capability. Agencies that already participate in CISA's Comprehensive Log Aggregation Warehouse (CLAW) may optionally route designated telemetry to that service as part of their storage or replication strategy. CLAW is not a required component of the LRA, but it can serve as one federal shared service that supports long-term retention, cross-agency visibility, and centralized access consistent with an Agency Logging Plan. For more information on CLAW, contact CLAWOperationsSupport@cisa.dhs.gov.

5.2 COLLECTION AND TRANSPORT PATTERNS

Agencies should select collection and transport patterns according to the source and the security outcome being supported.

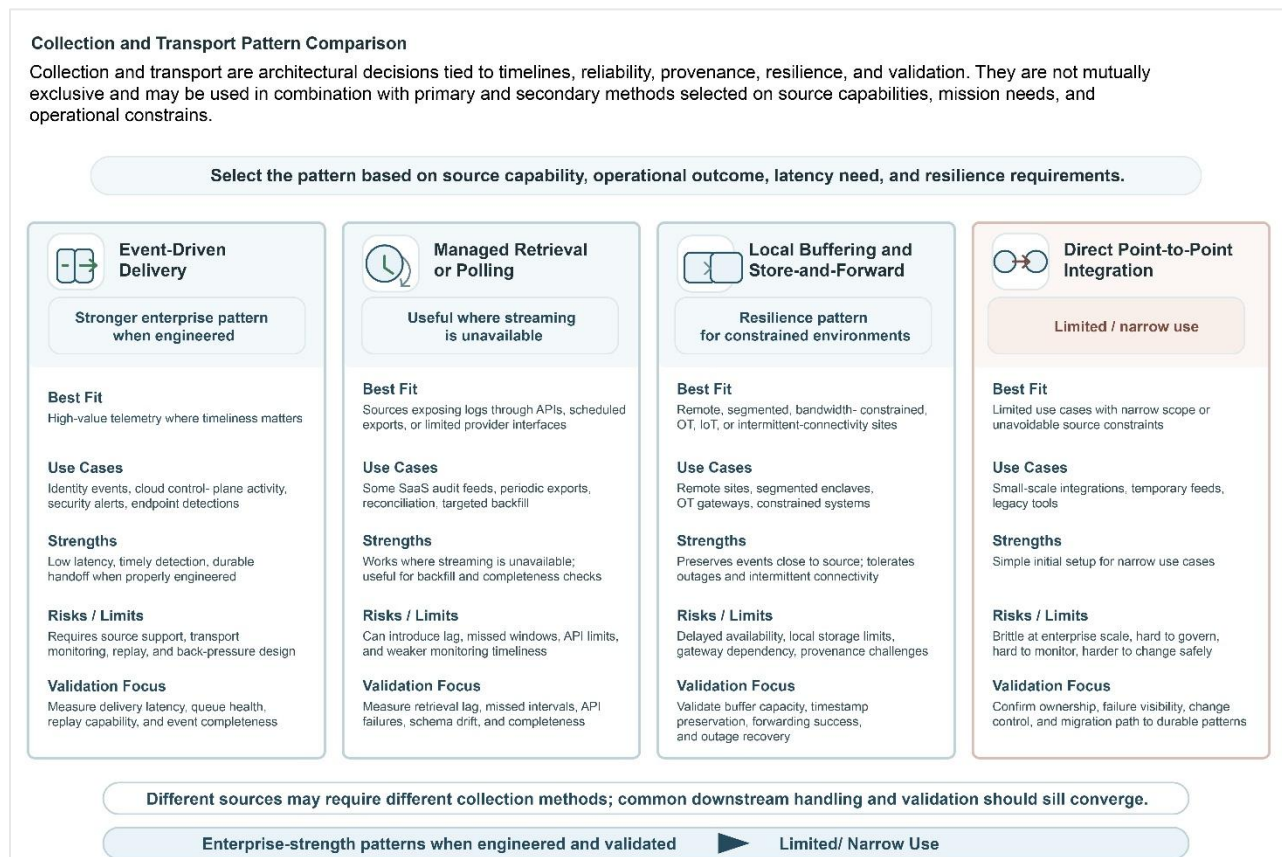


Figure 2: Comparison of Collection and Transport Patterns

Event-driven delivery is generally the preferred pattern for high-value security telemetry sources that support it. Native export, streaming delivery, brokered forwarding, and similar mechanisms should be favored where timeliness matters for monitoring or early response.

Retrieval and polling remain valid where a source exposes telemetry only through APIs, periodic export, or scheduled retrieval. Polling is useful as a bounded secondary capability for backfill, reconciliation, or recovery. Agencies should avoid letting it become the hidden default when operationally relevant telemetry could be delivered more directly.

Local buffering and store-and-forward patterns are appropriate where direct low-latency delivery would introduce operational strain or is not technically feasible. This is often true in remote, segmented, or specialized environments. Agencies should still expect those paths to preserve timestamps, provenance, integrity, and delivery awareness even if the data enters the broader logging infrastructure later.

Cloud and SaaS collection often relies on provider-native export, event buses, webhooks, administrative audit feeds, or APIs. Agencies should generally use the strongest available pattern that supports required timeliness, fidelity, and operational monitoring. Where only API-based retrieval is possible, those integrations should be treated as managed retrieval patterns and monitored for lag, missed records, schema drift, and provider-side change. This is especially important because cloud and SaaS environments often carry high-value identity and control-plane telemetry.

5.3 PROCESSING AND STORAGE PLACEMENT PATTERNS

Generally, the strongest processing pattern is shared downstream processing combined with source-appropriate collection. Under this pattern, sources enter the logging infrastructure through methods that fit their environment, but normalization, enrichment, schema enforcement, and validation are handled through common enterprise services or coordinated shared logic. This reduces redundant parsing, strengthens consistency, and makes change management more manageable over time.

Storage design should follow the required outcome, not convenience. Datasets needed for active monitoring, triage, and routine investigation should remain in storage tiers that support low-latency search. Datasets retained primarily for longer-horizon retrieval, forensic reconstruction, or oversight may move earlier into lower-cost tiers provided retrievability and integrity expectations are still met. Some designated datasets may require separate immutable handling. This distinction between actively **searchable** and **retrievable** retention should be explicit in the operating model.

M-26-14 requires retained logs to be actively searchable for a minimum of 6 months after creation to support CEM and retrievable for 1 year after creation to support THIRF.¹¹

While Appendix B of M-26-14 establishes the required baseline retention—that logs must be actively searchable for at least six months and retrievable for one year—the M-26-14 Appendix C Maturity Model defines staged progression levels used for assessing agency maturity. Under that model, Advanced (Level 3) requires only three months of searchable retention, with the six-month searchable window appearing at Optimal (Level 4).

¹¹ “M-26-14, App. B, Req. 1.: Ensuring Effective and Efficient Agency Logging and Network Visibility to Defend Against Evolving Cyber Threats,” Executive Office of the President and Office of Management and Budget, effective May 22, 2026, <https://www.whitehouse.gov/wp-content/uploads/2026/05/M-26-14-Ensuring-Effective-and-Efficient-Agency-Logging-and-Network-Visibility-to-Defend-Against-Evolving-Cyber-Threats.pdf>.

These two components serve different purposes: Appendix B defines mandatory baseline expectations for cybersecurity operations; Appendix C defines maturity benchmarks that agencies use to evaluate and report implementation progress. Agencies are required to reach Advanced (Level 3) within 320 days, and doing so satisfies maturity reporting requirements; however, agencies must still ensure their architectures meet the six-month searchable baseline in Appendix B to comply with M-26-14. The LRA reflects both requirements so agencies can distinguish baseline obligations from maturity progression milestones.

Agencies should also remember that **centralization is not the same as usefulness**. Moving every log into centralized storage with one analytical platform does not automatically improve monitoring or investigation. Centralization can improve consistency and visibility, but only if the data remains timely, trustworthy, and usable. A centralized storage design that strips away context, introduces major delay, or creates a fragile chokepoint is weaker than a more federated design with strong common governance and shared operational handling.

M-26-14 states that log storage may be decentralized but requires that logs must be readily available to the top-level agency SOC to achieve CEM and THIRF objectives.¹²

5.4 COMMON ARCHITECTURE PATTERNS

The following patterns are common ways agencies can structure enterprise logging. These are presented neutrally as neither the LRA nor M-26-14 requires one pattern for all agencies, though some patterns are generally stronger for a maturing environment than others depending on mission, existing investments, scale, and operational goals. [Australian Signals Directorate's \(ASD\) Implementing SIEM and SOAR platforms: Practitioner guidance](#) is a useful reference for these patterns. Agencies should prioritize the effectiveness of continuous event monitoring and THIRF objectives and optimization of the patterns relevant to their mission, resources, budgetary needs and architectural or physical constraints. Architectural pattern selection should prioritize resilience, provenance, and operational usability. Centralization alone does not guarantee effectiveness; poorly designed central chokepoints can degrade visibility.

5.4.1 Repository First

In a repository-first pattern, logs land first in a centralized repository, such as object storage, a data lake, a lakehouse, or other authoritative storage tier. Analytic platforms query or retrieve from that repository rather than ingesting every source directly. This pattern strengthens retention, preserves a durable system of record, and decouples storage from analytics. It is often a strong fit for agencies that need long-term retention, multi-team access, or the ability to evolve analytic tooling without recollecting data. Tradeoffs include the need for stronger data engineering, indexing strategy, and governance.

5.4.2 Dual Replication

In a dual-replication pattern, logs are sent simultaneously to a real-time analytic platform and a centralized repository. This is often useful during modernization, coexistence between enclaves, or migration between platforms. It can preserve current SOC workflows while strengthening retention and raw-fidelity storage elsewhere. Tradeoffs include higher ingest volume, duplicated or parallel operational paths, and the need to keep schemas, timestamps, and enrichment logic aligned across destinations.

¹² M-26-14 further states that agencies are encouraged to evaluate one or more approaches to achieve this objective, including considering the collection of logs via enterprise SIEM software, forwarding logs to a central location, setting appropriate access authorizations across distributed logs, or taking a hybrid approach that combines centralized storage with federated access.

5.4.3 Selective Feeds

In a selective-feeds pattern, routing logic determines which logs go to operational analytics and which go only to lower-cost or longer-term storage. This can reduce high-cost analytical ingest and help focus operational resources on the most useful datasets for continuous monitoring and response, while preserving broader context elsewhere for reconstruction and oversight. Tradeoffs include governance complexity and the risk of over-filtering important data. This pattern works best when routing criteria are explicit, well-governed, and periodically validated.

5.4.4 SIEM First

In a SIEM-first pattern, logs are ingested first into an analytical platform, with optional later replication into other storage tiers. This is common in legacy or smaller environments with established workflows. It can be simple to operate initially, but it often becomes costly and less flexible as telemetry volume and retention expectations grow. It may also weaken fidelity if ingestion-time processing becomes the agency's only durable event representation. Practitioner guidance generally warns against treating a SIEM as the central data store for all logs where broader retention and flexibility are needed.

5.4.5 Segregated-Access Overlay

A segregated-access overlay is not a separate transport pattern so much as an access and policy pattern that can sit on top of other architectures. It uses logical separation, indexing, Role-Based Access Control (RBAC)/Attribute-Based Access Control (ABAC), partitioning, or encryption domains to control access to sensitive datasets such as personally identifiable information (PII), controlled unclassified information (CUI), mission-sensitive telemetry, or other restricted content. This pattern can support least-privilege access without duplicating entire pipelines, but it introduces additional governance and operational complexity. It is particularly relevant where agencies need shared storage and analytics but have different access boundaries for different user populations or missions.

5.5 SPECIALIZED ENVIRONMENT PATTERNS

Some environments need stronger or adapted versions of the default operating model.

Cloud and SaaS environments often require a mix of native export, API retrieval, and provider-specific audit feeds. Agencies should treat cloud identity and administrative telemetry as high priority because weaknesses there often have outsized operational consequences. Dataflow patterns should be designed so cloud control-plane activity can be correlated with endpoint, identity, and network context rather than handled in isolation.

HVAs may require stronger fidelity, longer searchable windows, more explicit provenance, stricter segmentation, or dedicated immutable handling. These are not necessarily separate architectures, but they often require different thresholds for what constitutes acceptable coverage, latency, and retention.

OT, IoT, and constrained environments may depend on gateway aggregation, segmented forwarding, store-and-forward, or scheduled transfers patterns. Agencies should avoid imposing collection methods that degrade operational safety or reliability. The requirement to preserve timing, provenance, and enough context for investigation still applies. The collection method may differ; the need for trustworthy telemetry does not. For further IoT/OT recoverability constraints, see Section 6.2.9.

Zero Trust Architectures (ZTA) should explicitly identify which identity, device, network, application/workload, and data-control decisions require logging for both north-south and east-west activity. This includes internal segmentation, workload-to-workload access, remote administration, federated identity events, and high-value application access paths.

AI systems are software systems, but they require unique considerations for logging. To support continuous event monitoring and threat hunting, investigation, response and forensics goals in AI systems, organizations should log user prompts, system prompts, model outputs, and other parameters used when interacting with an AI model, as well as the decisions and actions taken by AI agents and any interactions with external functions or components. Agencies should also capture basic model history, such as model versions and other lineage information, along with security-relevant events and indicators of possible manipulation of data or the system. Because these systems often rely on ephemeral infrastructure, logging approaches must make sure that important runtime details and non-human identities are recorded before they expire or are recycled. Logging in these environments should provide enough context to help distinguish expected model behavior from potential guardrail bypasses, prompt manipulation, or other forms of adversarial misuse.

Security Orchestration, Automation, and Response (SOAR) platforms can further enhance response effectiveness in mature environments by automating selected incident-response actions through predefined playbooks. When integrated with a SIEM, SOAR workflows rely heavily on accurate normalization, reliable transport, and consistent event fidelity; immature or noisy SIEM pipelines can significantly degrade SOAR performance. Agencies considering automation should ensure playbooks are tightly scoped, periodically validated, and aligned to operational risk tolerances. Additional implementation considerations, including automation risks, resource requirements, and integration patterns, are outlined in the Implementing SIEM and SOAR Platforms: Practitioner Guidance.¹³

6. BASELINE LOGGING COVERAGE AND MINIMUM EVENT FIDELITY

This section defines the baseline logging coverage and minimum event fidelity agencies should address when developing or updating their Agency Logging Plan. The purpose of the section is to translate policy-driven baseline expectations into practical coverage and data-quality requirements that support continuous event monitoring, threat hunting, incident response, and digital forensics.

Baseline alignment is not demonstrated by listing log sources alone. Agencies should show that they collect and retain data that is sufficiently complete, timely, attributable, and usable to support the required security outcomes. Activities that may demonstrate these achievements could include continuous validation of the logging pipeline, including monitoring for dropped feeds, schema, and normalization errors. A source can exist in the environment and still fail operationally if the events are delayed, too sparse, improperly parsed, missing key context, or unavailable to the teams that need them. Agencies should therefore treat baseline coverage as a question of usable capability, not nominal connector presence.

6.1 BASELINE LOGGING REQUIREMENTS

At the baseline level, the logging capability should support a core set of security activities that agencies are expected to perform across systems, services, and environments in scope. These activities include identity attribution, device attribution, network attribution, visibility into object and data activity, privileged and administrative change visibility, security-tool visibility, IOC and anomaly detection support, incident impact assessment, and attack-path reconstruction.

¹³ "Implementing SIEM and SOAR platforms: Practitioner guidance," Australian Signals Directorate's Australian Cyber Security Centre (ASD's ACSC), effective May 27, 2025, <https://www.cyber.gov.au/business-government/detecting-responding-to-threats/event-logging/implementing-siem-soar-platforms/implementing-siem-and-soar-platforms-practitioner-guidance>.

The baseline logging capability should also support the generation of appropriate automated alerts for the baseline activities described below, and in alignment with the M-26-14 Appendix B Requirement 5(k). Tie alerts to the underlying telemetry and analytic logic needed for triage, validation, scoping, and follow-on investigation; they should not replace the underlying event records required for continuous event monitoring and threat hunting, investigation, response, and forensics.

In practical terms, that means an agency's baseline logging capability should support the ability to determine:

- What identity or principal performed an action
- What network communications or sessions occurred
- What object, resource, or data activity took place
- What actions changed privilege, configuration, or authoritative control state
- What suspicious activity was observed by security tooling
- Whether known IOCs or anomalous patterns are present
- What data, systems, or services were impacted during an incident
- How an attack progressed, including initial access, privilege change, lateral movement, and data impact

Agencies may also use CDM MNGEVT audit data collection expectations as a design input when defining minimum event fields, including attributes that support “who,” “what,” “when,” and “where” analysis across log sources. This baseline should be treated as the floor, not the ceiling. Agencies may need deeper endpoint telemetry, richer application logging, more complete cloud workload visibility, longer search windows, or more detailed resource and object activity based on mission, system criticality, or threat profile. But those above-baseline decisions should be built from a sound baseline, not substitute for one.

6.2 MINIMUM EVENT FIDELITY

To make the baseline operational, agencies should organize required telemetry into a set of common logging categories and define the minimum event fidelity needed for each category to be useful. The categories below are intended to support cross-agency consistency while preserving flexibility in the underlying source technologies and platforms.

For environments implementing zero trust controls, agencies should ensure baseline logging preserves decision context relevant to identity, device trust, segmentation, workload access, and data access. This commonly includes authentication strength, multifactor authentication (MFA) result, device posture or compliance state, policy evaluation outcome, privilege elevation context, remote access context, segmentation decision, and data access or sharing decision context where available.

6.2.1 Identity and Authentication Activity

This category supports identity attribution, detection of suspicious access behavior, threat hunting for credential misuse, and reconstruction of authentication sequences. At minimum, records in this category should preserve the identity or principal context, timestamp, authentication or access event type, outcome, and relevant source, device, or session context where available. In a mature design, this category should also support pivots across authentication attempts, session activity, MFA events, privilege use, and administrative actions.

Agencies should also continue to build on identity-focused analytics capabilities developed under M-21-31, including user and entity behavior analysis and other advanced identity-centric detection methods. These capabilities remain valuable under M-26-14, particularly in enhancing continuous event monitoring through detection of anomalous identity activity, credential misuse, lateral movement, and privilege abuse.

While the baseline requirements in this section reflect the minimum telemetry needed for identity attribution, agencies are encouraged to maintain and advance higher-fidelity identity analytics—especially where AI-enabled techniques can improve behavioral baselining, anomaly detection, and triage. These above-baseline capabilities support stronger CEM and THIRF outcomes and should be preserved rather than scaled back as agencies transition from M-21-31 to M-26-14.

6.2.2 Network Activity

This category supports communication analysis, tracing of paths between systems, lateral-movement analysis, and identification of suspicious destinations or protocols. At a minimum, records should preserve source and destination network addressing, protocol, port, timestamp, and session or connection attributes where available. Agencies should take special care not to reduce this category to coarse summaries that are insufficient for path reconstruction, segmentation analysis, or high-confidence pivoting during incident response.

6.2.3 Object, Resource, and Data Activity

This category supports integrity monitoring, impact assessment, and scoping of what was accessed, modified, created, destroyed, or transferred. At a minimum, records should preserve the object, resource, or data context, the action taken, the associated identity or system context, timestamp, and outcome, where applicable. Agencies should be cautious here: object- and data-level visibility is often one of the first places where fidelity becomes too weak for forensic reconstruction or impact assessment.

Although the M-26-14 requirement does not explicitly require logging of created and exfiltrated objects or data, it is operationally important for enabling complete forensic impact analysis, detecting malicious file creation or propagation, and identifying unauthorized data transfers. The LRA includes “created” and “exfiltrated” in its recommended above-baseline fidelity guidance to support full CEM and THIRF outcomes, but these elements should not be interpreted as additional policy mandates.

6.2.4 Privileged and Administrative Activity

This category supports attribution of changes that affect privilege levels, administrative state, configuration, or authoritative control settings. At a minimum, records should preserve actor identity, privileged or administrative action, target system or resource, timestamp, and outcome. For many agencies, this category deserves special attention because weaknesses here disproportionately degrade incident scoping and trust in downstream analysis. Administrative and privilege changes that cannot be reliably attributed are among the most damaging logging gaps an agency can carry into an incident.

6.2.5 Endpoint and System Activity

This category supports visibility into host activity, relevant process execution, system-level changes, and actions affecting IT, OT, and IoT infrastructure. At a minimum, records should preserve device or system identity, relevant activity or process context, associated identity or system context where available, timestamp, and action or result. Agencies should distinguish between lightweight host status indicators and the richer event context required for threat hunting, lateral-movement analysis, and timeline reconstruction.

6.2.6 Security Tool Alerts and Detections

This category supports alert triage, workflow initiation, enrichment of broader investigations, and correlation with source events. At a minimum, records should preserve alert or detection type, source security tool, affected asset, account, or resource where applicable, timestamp, severity or priority where available, and enough analytic context to understand why the alert was generated. Agencies should not assume that tool alerts alone satisfy broader logging requirements. Alerts are useful signals, but they are not substitutes for the underlying event data needed to validate, scope, and reconstruct activity.

6.2.7 Cloud and SaaS Administrative Activity

This category supports attribution, configuration-change analysis, control-plane monitoring, and investigation of suspicious administrative actions in cloud and SaaS environments. At a minimum, records should preserve actor identity, administrative or control-plane action, target resource or service, timestamp, outcome, and relevant request or session context where available. Because cloud and SaaS identity and administrative actions are often pivotal to modern intrusions, agencies should treat this category as core enterprise telemetry rather than as a specialized add-on.

6.2.8 High Value Assets and Specialized Environments

This category captures additional telemetry needed to support baseline outcomes in environments that require stronger fidelity or specialized collection approaches. These may include HVAs, OT environments, IoT devices, public-facing mission systems, and highly sensitive data-processing environments. At a minimum, the category should preserve the identity, activity, change, timing, and context necessary to support attribution, detection, investigation, and impact analysis appropriate to the environment. The exact telemetry may vary, but the operational standard should not be lower just because collection is harder.

6.2.9 IoT and OT Device Activity (Including Environments Without Native Logging)

IoT and OT environments require adaptations to baseline logging coverage due to operational constraints, as described in Sections 4.3 and 5.5. This category supports visibility, configuration-change awareness, and investigative reconstruction across devices, including those without native logging. At a minimum, IoT/OT telemetry should enable attribution of device activity, identification of configuration or state changes, and correlation with broader network, identity, and administrative context. The LRA may rely on the following environment-appropriate mechanisms to satisfy baseline expectations in constrained IoT/OT environments. Where native logging is unavailable, agencies may use gateway aggregation, network-based monitoring, scheduled polling, or store-and-forward patterns to collect relevant telemetry.

Regardless of collection method, the minimum usable fidelity defined in Section 6.2 applies—records must preserve timestamp accuracy, provenance, operator or system context, and sufficient detail to support correlation and reconstruction. IoT/OT logging decisions should therefore be documented in the Agency Logging Plan using the same structure as other environment-specific considerations, consistent with Appendix C and the validation prompts in Section E.1 for constrained environments.

6.3 COMMON FIELDS REQUIRED FOR OPERATIONAL USABILITY

Across all baseline categories, agencies should preserve a common set of fields that make data usable across tools and teams. At a minimum, event records that support enterprise operations should preserve:

- A reliable timestamp
- An identifiable event or action type
- Identity or system context, where applicable
- The affected device, resource, service, or dataset, where applicable
- The result or outcome, where applicable
- Provenance sufficient to determine where the record originated and how it entered the logging infrastructure

These common fields are not enough by themselves for every use case, but they are the minimum foundation for correlation, pivots, and cross-source operations. Where the required outcome depends on session context, privilege state, network context, object-level detail, or request parameters, those characteristics should also be preserved. For example, timestamp reliability depends on more than field presence. Agencies should synchronize network time using Network Time Protocol (NTP) or equivalent mechanisms to a traceable time source designated by the agency. Where feasible, agencies should use authoritative time sources traceable to the U.S. Naval Observatory or NIST. The Agency Logging Plan should identify how time synchronization is implemented, monitored, and validated for major telemetry sources. Agencies should avoid defining a “common schema” so narrowly that it becomes operationally shallow. Common fields should make cross-source work possible, not force analysts to rebuild context manually every time they pivot.

6.4 COVERAGE AND FIDELITY GAPS THAT MATERIALLY DEGRADE OPERATIONS

A baseline logging capability can still fail operationally even when the agency believes coverage exists. For a maturing agency, it is useful to name the failure modes that matter most so they can be explicitly tested and addressed.

One common failure mode is source presence without usable detail. The source is onboarded, but the record lacks enough context to support scoping, threat hunting, or reconstruction. Another is retention without searchability: the data exists, but not in a tier or structure that supports timely operational use. A third is normalized data without recoverable source meaning, where the data supports dashboards or counts but not actual investigation.

Other material gaps include:

- Incomplete cloud control-plane and SaaS administrative visibility
- Weak identity attribution across systems and services
- Unreliable or inconsistent timestamps across major telemetry classes
- Privileged or administrative actions that cannot be tied to actors and targets
- Missing object, resource, or data activity needed for impact analysis
- Alerting pipelines that are present but cannot be validated against raw or high-fidelity context
- Inability to correlate identity, endpoint, network, and cloud records through common pivots

These gaps materially affect the agency’s ability to detect, hunt, respond, and reconstruct activity. The Agency Logging Plan should therefore identify not only baseline coverage targets, but also the principal coverage and fidelity gaps that still materially weaken operations.

7. SCHEMA, NORMALIZATION, AND INTEROPERABILITY

This section defines the expectations agencies should address so that baseline and above-baseline logging data remains usable across tools, teams, and authorized sharing paths. Agencies will inevitably collect telemetry from multiple products, platforms, services, and environments, each with different source-native structures and semantics. The LRA does not require a single vendor schema or a single normalization point. It does require the agency to maintain a usable normalized representation of security-relevant events somewhere in the pipeline and to preserve enough source-native context to support operational and forensic work when the normalized record alone is not sufficient. Distributed or inconsistent mapping logic creates drift that undermines detection, correlation, and investigation. Agencies should maintain governed, testable schema and parser management processes.

CDM MNGEVT provides a useful design reference for interoperability and correlation because it addresses standard log formats, searchable and retrievable audit data, analysis and alerting, and integration of operational log-based and network flow sources. Where agencies use AI- or ML-enabled analytics to enrich telemetry or generate analytic outputs, those outputs should be represented as derived data, not as replacement or authoritative event content. Agencies should preserve the relationship between the original record and the derived output and should record enough metadata to support review, reproduction, and challenge of the result.

7.1 NORMALIZATION

Agencies should normalize the key event characteristics needed for durable cross-source operations. The purpose of normalization is not to make every event look identical. The purpose is to enable consistent search, correlation, detection, pivoting, reporting, and investigation across otherwise incompatible log sources. Without some level of durable normalization, agencies tend to accumulate brittle, source-specific content that is harder to govern, slower to use during an incident, and more dependent on the intricacies of individual tools. At a minimum, normalized event records should preserve common operational fields such as:

- Event time
- Event or action type
- Identity or system context
- Affected device, resource, service, or dataset
- Outcome or result
- Provenance

Agencies should also normalize additional context where necessary for the use case, such as session identifiers, request parameters, source and destination network context, privilege context, and parent-child execution relationships. What matters is that the normalized record supports the agency's actual operational questions, not just a generic reporting model.

The normalized representation should be durable enough to support enterprise operations over time. Agencies should not rely solely on ephemeral query-time transformations unless they are confident those transformations remain stable, governed, and operationally available when needed. The right implementation point may vary, but the architectural requirement is the same: the agency should be able to work across sources through a consistent enough representation that analysts are not forced to learn and reconcile dozens of incompatible event structures during active investigations.

7.2 SOURCE-NATIVE CONTEXT FOR RECOVERABILITY

Normalization is necessary, but it is not sufficient. Agencies should preserve enough source-native context so that operators can still understand what happened in the originating system or platform. This is especially important in threat hunting, incident response, and digital forensics, where normalized records often help analysts find the relevant activity, but source-detailed context is needed to interpret meaning, verify hypotheses, or reconstruct a timeline precisely. Normalized data should improve operational usability without destroying the underlying meaning of the source record. In practice, recoverable source-native context may include fields such as:

- Detailed authentication attributes
- Cloud request parameters
- Process arguments and parent-child process information
- Object-level access details

- Source tool or platform-specific classification fields
- Original event codes or action names
- Full or equivalent detailed records used for validation or forensic review

The agency does not necessarily need every raw event in every operational tier. It does need a reliable path to the fuller source meaning when the normalized record is not enough. The Agency Logging Plan should therefore specify what source-level detail remains recoverable, where it resides, and how analysts or investigators will access it when needed. For recoverability of IoT/OT, see Section 6.2.9.

7.3 SCHEMA GOVERNANCE AND CHANGE MANAGEMENT

Agencies should establish governed processes for source onboarding, field mapping, schema changes, parser maintenance, and downstream dependency management. This is not a paperwork exercise. It is one of the main ways an agency prevents silent degradation in detections, dashboards, hunting workflows, and incident-response pivots as sources evolve over time. Mapping accuracy, field presence, timestamp reliability, and preservation of required context are all operational concerns, not just data-quality concerns. Agencies should be especially careful where normalization logic or field mappings are distributed across multiple tools or teams. Distributed logic often leads to inconsistent representations of the “same” event or entity, which in turn makes enterprise correlation and validation harder. A maturing agency does not need all mapping logic in one place, but it does need consistent governance over how meaning is represented.

At minimum, governance should define:

- How new sources are onboarded
- What fields are required for each baseline category
- How mappings are validated before and after deployment
- How parser failures, unmapped values, and drift are detected
- How downstream content that depends on those fields is identified and tested
- How rollback is handled if a change degrades operational use

7.4 PORTABILITY, FEDERAL INTEROPERABILITY, AND AUTHORIZED SHARING

Agency logging data must remain portable enough to support internal use, transition across platforms where needed, and authorized sharing under policy-governed conditions. The agency should normalize data first for its own operational benefit. Even if a downstream federal capability performs additional transformation or normalization for its own use, that does not remove the agency’s need to maintain usable, portable data locally.

Portability matters for several reasons. First, agencies need the ability to move or reuse data across platforms and tools without losing core meaning. Second, agencies need to avoid becoming operationally dependent on proprietary structures that make it difficult to export, validate, or reinterpret security-relevant data. Third, authorized sharing often requires the agency to produce a stable subset or profile of normalized data that preserves required meaning while still supporting minimization, redaction, and policy enforcement.

The agency logging plan should describe how the agency will support lawful requests for logs and other relevant data from CISA, the Federal Bureau of Investigation (FBI), Office of Inspector General, courts, or legal counsel. This should include the technical, operational, and governance steps needed to identify relevant datasets, integrity preservation, access, format, and required timeframes. To support these obligations, agencies should design logging solutions to ensure relevant records can be located, scoped, exported, and interpreted within necessary timeframes. This includes maintaining usable timestamps, trusted origin, context, access records, and documentation of any transformations, reductions, or redactions applied prior to data sharing or access outside the agency.

Portability and interoperability do not mean every source must be translated into a single universal interchange format. It does mean the agency should know:

- What its durable normalized event record looks like
- What source-native context remains accessible
- How data can be exported or translated without losing critical meaning
- How authorized shareable subsets are produced and governed

These questions should be answered in the Agency Logging Plan because they affect continuity, collaboration, and operational independence over time.

8. LOGGING INFRASTRUCTURE SECURITY, INTEGRITY, AND RESILIENCE

Agencies should treat the logging infrastructure as a mission-critical system and a high value target. If it is compromised, blinded, silently degraded, or rendered untrustworthy, the agency loses not only monitoring capability but also confidence in investigation, response, and forensic reconstruction. This section therefore addresses three connected requirements: protecting the logging infrastructure itself, preserving the integrity and provenance of records that move through it, and ensuring the capability remains resilient under failure, attack, and change.

8.1 PROTECTING THE LOGGING INFRASTRUCTURE

Agencies should protect the logging infrastructure as a security-critical capability whose compromise can blind detection, corrupt evidence, disrupt sharing, or undermine confidence in downstream decisions. This includes collection infrastructure, transport layers, queues or brokers, normalization and processing stages, storage tiers, analytical platforms, administrative interfaces, and any policy-enforcement functions applied to logging data. Treating only the SIEM or main analytics tier as the critical asset is too narrow. Capability trustworthiness depends on the whole path. At a minimum, agencies should apply:

- Strict administrative access control
- Separation of duties where practical
- Least privilege for users, service accounts, and integrations
- Logging and monitoring of privileged activity affecting the logging infrastructure
- Protections against unauthorized change, deletion, or silent bypass
- Segmentation or isolation appropriate to the sensitivity and mission role of the capability

The exact implementation may vary, but the outcome should be the same: the agency can trust that required telemetry is being collected, handled, and exposed to operators as intended, and that privileged actions affecting the logging infrastructure are controlled and auditable. Agencies should also consider evaluating whether key components of the logging infrastructure meet their criteria for HVAs or other elevated protection categories and, where applicable, incorporate them into those inventories and governance processes.

NIST SP 800-61 Rev. 3 is relevant here because it emphasizes incident records, evidence handling, coordination, and recovery activities as part of broader cybersecurity risk management. Logging infrastructure security is not just a technical hardening issue. It is part of the agency's ability to preserve trustworthy records during and after incidents.

8.2 INTEGRITY PROTECTIONS AND EVIDENTIARY CONSIDERATIONS

Agencies should preserve the integrity and provenance of logging data in a way that supports operational confidence and, where required, evidentiary use. Not every dataset needs the same handling, but the agency should explicitly designate which datasets require stronger controls and why. Apply integrity protections consistently—at collection, during transport, in storage, and during access—not only as a retention-focused measure. Depending on the use case, integrity protections may include:

- Cryptographic hashing upon upload, movement, and access to ensure veracity and integrity verification
- Signing
- Immutable or write-once handling
- Auditable transfer paths
- Access logging
- Documented acquisition and handling procedures
- Preservation of provenance and transformation history

The key architectural point is that the agency should not assume all log records need identical controls, but it also should not leave stronger handling undefined until an incident occurs. The Agency Logging Plan should identify:

- What datasets require immutable or tamper-evident handling
- What level of provenance must be preserved
- Who can access or handle those datasets
- What procedures apply when records are needed for investigation, review, or evidentiary purposes

Agencies should also avoid treating integrity as a storage-only issue. Integrity can be degraded at collection, during forwarding, through parser behavior, by unnoticed transformation, or through privileged administrative action. A trustworthy logging infrastructure therefore depends on integrity protections across the full path, not only at rest. CDM MNGEVT also reinforces the need for integrity-protected or tamper-evident audit log data when logs are in transit or at rest.

8.3 RESILIENCE AND FAILURE HANDLING

A sound logging architecture should continue operating through partial failure and make degradation visible before it becomes a major operational problem. This includes failures in collection, transport, parsing, normalization, storage, indexing, and downstream analytics. At a minimum, agencies should plan for:

- Local buffering where needed
- Durable transport or queuing
- Replay or backfill mechanisms
- Detection of delayed or missing delivery
- Parser failure handling
- Downstream back pressure
- Health monitoring for critical pipeline stages
- Clear recovery procedures after partial outage or data-path interruption

These are not simply performance optimizations. They determine whether the agency can preserve continuity of logging operations when parts of the environment fail or come under stress. If a collector loses connectivity, a queue backs up, a parser starts dropping fields, or a downstream storage or analytics tier becomes unavailable, the agency should know how the architecture behaves, what data may be delayed, what can be replayed, and what visibility is temporarily degraded. A mature logging capability must continue functioning through partial failures, detect degradation early, and support replay or backfill when data delivery is disrupted.

Agencies should avoid strategies not aligned with this LRA, including the following sub-optimal strategies that can negatively impact operational logging capabilities:

- Overreliance on direct point-to-point integrations
- Treating polling as the default where timeliness matters
- Centralizing all telemetry into a single fragile pipeline
- Normalization that discards investigative context
- Unmanaged exceptions that bypass policy enforcement
- Vendor-dependent handling that leaves essential telemetry outside agency control

From an Agency Logging Plan perspective, the resilience question should be written directly: How does the agency detect degradation, recover missed data, preserve trust during partial failure, and validate that required datasets remain complete and usable over time? A mature answer to that question is one of the clearest indicators that the logging capability is more than a collection stack.

9. RISK-INFORMED LOGGING BEYOND THE BASELINE

M-26-14 defines the minimum logging baselines and requirements agencies must meet to support federal security objectives. However, it does not fully determine what the agency should collect, retain, or validate beyond that minimum. Many agencies operate mission-specific systems, HVAs, cloud-centric environments, public-facing services, air-gapped networks, and/or specialized operational technologies that require additional visibility or stronger telemetry fidelity than the baseline alone provides. This section uses a threat- and risk-informed approach to provide a practical method agencies can use to prioritize and determine where additional logging may be needed above the required baseline.

9.1 UNDERSTANDING THREAT AND RISK PROFILES

A threat- and risk-informed approach to log management starts by identifying the systems, services, and business or mission functions that would pose the greatest impact if they were to be compromised. For the purposes of this LRA, a **threat profile** identifies the adversaries, objectives, and common TTPs most relevant to the agency. A **risk profile** identifies the systems, data, services, and/or processes whose compromise would have significant mission, operational, legal, or public consequences.

These profiles do not need to be exhaustive to be useful. A few representative threat scenarios and mission-critical systems are often enough to guide meaningful logging decisions. Useful inputs include:

- Incident history
- Strategic, tactical, operational, and technical threat intelligence
- Red team or penetration testing results
- Mission impact assessments
- Architectural knowledge of critical systems and trust relationships
- Mappings to relevant ATT&CK techniques¹⁴ or similar adversary-behavior models

The practical output of this analysis is not a long threat report embedded in the Agency Logging Plan. It is a defensible explanation of why certain additional telemetry, fidelity, or retention decisions are necessary for the agency's environment.

9.2 VISIBILITY-INFORMED ASSESSMENT OF CURRENT STATE

Threat and risk considerations should be paired with an assessment of the current visibility into the agency's environment. Agencies should know what telemetry they intend to collect and why, what telemetry they currently have, where major blind spots exist, and whether they materially weaken the agency's security posture. A practical visibility-informed assessment should identify:

- The current telemetry inventory by category and environment
- Where authoritative sources are not yet connected or are not producing usable alerts
- Where fidelity is too weak to support investigation or reconstruction
- Where searchability or retention is inadequate for hunting or response
- Where enterprise visibility is fragmented by enclave, product, or ownership boundary
- Where important attack paths cross domains that cannot currently be correlated

9.3 METHOD FOR DETERMINING ABOVE-BASELINE LOGGING

Agencies should use a repeatable method for deciding where additional logging is justified.

Step 1: Identify mission-critical assets and services.

Determine what systems, services, identities, data stores, applications, and operational environments would cause significant mission or operational harm if compromised. This may include HVAs, cloud identity systems, public-facing mission systems, enterprise authentication services, OT environments, or regulated data-processing systems.

Step 2: Map relevant threat scenarios to those assets.

Using the agency's threat profile, identify the most relevant or highest-consequence adversary behaviors affecting those assets. Examples might include credential theft, cloud privilege escalation, data exfiltration, misuse of administrative access, lateral movement across workstation or server tiers, or disruption of OT.

Step 3: Identify the investigative questions the agency must be able to answer.

For each scenario, determine what analysts, responders, or investigators must be able to determine during monitoring or incident response. Examples include:

- Can the agency reconstruct credential use across cloud and on-premises systems?
- Can it determine who changed a privileged role assignment and from where the change was made?

¹⁴ "MITRE ATT&CK," The MITRE Corporation, accessed July 17, 2026, <https://attack.mitre.org/>.

- Can it measure the scope and timing of data exfiltration?
- Can it verify integrity changes to critical files, services, or controller configurations?

Step 4: Translate those questions into telemetry, fields, fidelity, and retention.

Once the questions are defined, identify the specific log sources, fields, metadata, timing expectations, and retention characteristics needed to answer them. This may involve richer authentication context, cloud control-plane logging, detailed endpoint telemetry, east-west network visibility, application or API activity, object-level data-access events, or more detailed administrative logs. The agency should also decide whether the additional telemetry must be operationally searchable, only retrievable, or handled with stronger integrity protections.

Step 5: Integrate those decisions into architecture, validation, and cost management.

Above-baseline logging decisions are not complete until they are integrated into the actual logging architecture. The agency should decide how the additional telemetry will be collected, transported, normalized, stored, protected, and validated—and what operational and financial tradeoffs result. Above-baseline telemetry that exists only on paper or only in one enclave is not a reliable enterprise capability.

9.4 DOCUMENTING ABOVE-BASELINE DECISIONS IN THE AGENCY LOGGING PLAN

Agencies should record above-baseline decisions directly in the Agency Logging Plan rather than treating them as informal engineering preferences. At a minimum, the plan should document:

- What additional telemetry or fidelity is required
- What systems or environments they (the decisions) apply to
- What mission, threat, or visibility gap justifies them
- What retention and integrity implications they have
- How the agency will validate that they are available and usable

This creates clarity, defensibility, and continuity over time. It also makes it easier for agencies to revisit above-baseline choices as missions, technologies, and threat conditions evolve. A good Agency Logging Plan should therefore make obvious which parts of the capability are baseline, which are above baseline, and why the agency chose to invest beyond the floor.

10. USING AI FOR CEM AND THIRF PRODUCTIVITY ENHANCEMENTS

Agencies may use AI- and ML-enabled capabilities to enhance CEM and THIRF, particularly where the volume, velocity, or complexity of telemetry makes manual analysis alone insufficient. Examples include anomaly detection, alert prioritization, event correlation and enrichment, weak-signal discovery, query assistance, incident timeline reconstruction, and summarization of large investigative datasets. Treat these capabilities as optional enabling methods within the logging architecture, not as substitutes for required telemetry.¹⁵ Where agencies use AI-enabled solutions, the Agency Logging Plan should identify the intended security use cases, data inputs, validation approach, human review points, fallback procedures, and any authoritative or chain of custody needs to distinguish event records from model-generated scores, summaries, recommendations, or other derived outputs. Agencies should implement these capabilities consistent with applicable federal AI policy and guidance.

¹⁵ “Artificial Intelligence Risk Management Framework (AI RMF 1.0),” National Institute of Standards and Technology, effective January 2023, <https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>.

10.1 EXAMPLE USE CASES

These use cases should align with agency mission risk, operational priorities, and existing cybersecurity processes. If these AI capabilities meet the definition of “high-impact AI” in M-25-21, agencies should inventory, assess, and govern them in line with that memorandum, including documenting their use cases, safeguards, and oversight.

Table 1: AI for CEM and THIRF Example Use Cases

Area	AI Enhancement	LRA Boundary Condition
CEM	Anomaly detection, alert correlation, alert prioritization, behavioral baselines, detection tuning, noise reduction	Must remain tied to underlying event records, validated detections, and analyst-reviewable rationale.
Threat Hunting	Weak-signal discovery, suggested pivots, entity relationship analysis, query assistance, pattern discovery	Must augment analyst hypotheses and preserve access to searchable sources and normalized records.
Investigation and Response	Incident summarization, timeline reconstruction, entity scoping, triage assistance, recommended next investigative steps	Material containment, disclosure, legal, privacy, or mission-impacting actions require human review.
Forensics	Large-dataset triage, relationship discovery, prioritization of records for review	Must not alter source evidence, replace chain-of-custody controls, or become the authoritative record.
Logging Operations	Parser-failure detection, schema-drift detection, source-volume anomaly detection, pipeline health anomaly detection	Should support validation and observability of the logging capability.

11. MATURITY PROGRESSION FOR FEDERAL AGENCIES

Agencies do not begin at the same point, and they should not be expected to mature their enterprise logging capabilities in one step. For this reason, M-26-14 establishes the Logging Maturity Model for an Information system. The discussion in this section is an implementation aid and does not replace the M-26-14 maturity model. Agencies should assess and report maturity using the M-26-14, Appendix C elements: Inventory Visibility, Collection Coverage, Collection Operations, Data Retention, and Log Management. The narrative stages below are intended to help agencies understand common implementation patterns and improvement priorities as they progress through those required levels.

Agencies should maintain a clear understanding of their current logging capabilities, including strengths, gaps, and areas of operational dependency. As part of maturity progression, agencies should routinely assess their implementation posture, identify coverage or fidelity gaps, and prioritize improvements based on operational risk, mission impact, and historical lessons learned from incidents. Documenting findings from investigations, response activities, and recurring operational challenges enables agencies to refine detection logic, strengthen pipeline reliability, and enhance future readiness.

Although M-26-14 supersedes M-21-31, prior assessments completed under M-21-31 remain valuable baselines; when evaluated alongside the LRA's architectural criteria and maturity measures, they can help agencies identify capability gaps, continuity risks, and high-value opportunities for enhancement.

This section provides maturity progression details to help agencies recognize where they are, their assessed maturity level, and likely next steps. The three stages will help agencies sequence improvements and communicate progress as they mature their capability.

Element	Ineffective (Level 0)	Initial (Level 1)	Intermediate (Level 2)	Advanced (Level 3)	Optimal (Level 4)
Inventory Visibility	The Level 1 requirements for this area are not met.	A minimum of 70% of IT/OT/IoT assets associated with the system are captured in a centralized HWAM/SWAM inventory.	A minimum of 80% of IT/OT/IoT assets associated with the system are captured in a centralized HWAM/SWAM inventory, and the data is updated daily.	A minimum of 90% of IT/OT/IoT assets associated with the system are captured in a centralized HWAM/SWAM inventory, and the data is updated daily.	A minimum of 95% of IT/OT/IoT assets associated with the system are captured in a centralized HWAM/SWAM inventory, and the data is updated daily.
Collection Coverage	The Level 1 requirements for this area are not met.	The system logs required by the Agency Logging Plan are searchable and retrievable for at least 50% of the HW/SW assets in the system inventory. Log aggregation occurs in a timely manner.	The system logs required by the Agency Logging Plan are searchable and retrievable for at least 80% of the HW/SW assets in the system inventory. Log aggregation occurs in a timely manner.	The system logs required by the Agency Logging Plan are searchable and retrievable for at least 90% of the HW/SW assets in the system inventory. Log aggregation occurs in a timely manner.	The system logs required by the Agency Logging Plan are searchable and retrievable for at least 95% of the HW/SW assets in the system inventory. Log aggregation occurs in a timely manner.
Collection Operations	The Level 1 requirements for this area are not met.	Logs generate actionable alerts covering <50% of minimum baseline logging requirements. Alerts are referenced in investigations on an ad hoc basis.	Logs generate actionable alerts covering 50–70% of minimum baseline logging requirements, and detections are periodically evaluated and tuned to enable CEM/THIRF outcomes.	Logs generate actionable alerts covering at least ≥70% of baseline logging requirements, and detections are routinely evaluated and tuned.	Logs generate actionable alerts, covering at least 95% of baseline logging requirements, and detections are routinely evaluated and tuned using advanced techniques such as machine learning or artificial intelligence.
Data Retention	The Level 1 requirements for this area are not met.	Logs are retained and retrievable for a minimum of 6 months.	Logs are retained and retrievable for a minimum of 12 months.	Logs are retained and searchable for a minimum of 3 months and are retrievable for a minimum of 12 months.	Logs are retained and searchable for a minimum of 6 months and are retrievable for a minimum of 12 months.
Log Management	The Level 1 requirements for this area are not met.	Logs are stored.	Logs are stored and encrypted at rest.	Logs are encrypted in transit and at rest, and regularly hashed for veracity.	Logs are encrypted, access is granted just in time, permissions and workloads are regularly monitored and reviewed, and logs that are retired are managed appropriately through two-gate approvals.

Figure 3: M-26-14 Logging Maturity Model for an Information System

11.1 MATURITY PROGRESSION STAGES

In **Stage 1**, the agency has some logging capability, but it is uneven, siloed, or primarily compliance driven. Source onboarding may exist for many systems, but enterprise visibility is fragmented by tool, enclave, or ownership boundary. Baseline telemetry categories may be partially present without consistently usable fidelity. Searchability may be limited or inconsistent across environments, and retention may be treated separately from operational use. Analysts often depend on manual pivots across multiple tools and inconsistent field meanings.

At this stage, the most important work is usually to close the largest baseline coverage and usability gaps and establish more consistent enterprise handling. Common characteristics of Stage 1 include:

- Uneven source coverage across major environments
- Weak or inconsistent cloud and SaaS control-plane visibility
- Limited correlation between identity, endpoint, network, and administrative data
- Alerts that cannot be easily validated against richer event context

- Little explicit distinction between actively searchable and retrievable data
- Limited validation of timeliness, completeness, or parser health
- Unclear or inconsistent handling of sensitive log data
- Agency Logging Plans that describe sources or tools but not architectural decisions

In **Stage 2**, the agency has begun to move from fragmented logging toward an enterprise capability. Baseline categories are more broadly covered, and the agency has started to establish shared or coordinated normalization, stronger enterprise visibility, and more deliberate retention and validation practices. The top-level SOC or equivalent enterprise security function has better access to required datasets, even if the architecture remains partially federated. Above-baseline logging may exist for some critical systems or threat scenarios, but it may not yet be complete or consistently validated.

At this stage, the agency's priority is usually to improve fidelity, resilience, provenance, and validation, while reducing remaining blind spots and strengthening the operational usefulness of the data for threat hunting and response. Common characteristics of Stage 2 include:

- Broad baseline coverage across major enterprise environments
- More consistent timestamps, field mapping, and normalized event representation
- Stronger pivots across identity, endpoint, network, cloud, and administrative domains
- Establishment of an operational search window for key datasets
- Clearer differentiation between actively searchable and retrievable retention
- Improved pipeline health monitoring and basic data quality checks
- Documented above-baseline decisions for selected critical systems or use cases
- Agency Logging Plans that begin to capture real design and governance choices

In **Stage 3**, the agency's logging capability is designed and operated as an enterprise security function rather than as a set of disconnected collection mechanisms. Architecture decisions are explicitly tied to monitoring, threat hunting, incident response, and digital forensics. Coverage and fidelity are validated rather than assumed. The logging infrastructure is treated as a high-value capability with explicit integrity, access, and resilience controls. Above-baseline logging is driven by mission, threat, risk, and visibility needs rather than by ad-hoc accumulation.

At this stage, the agency is not "finished." The environment, mission, and threat landscape will continue to change. But the agency has reached a point where logging capability can be improved deliberately and validated continuously rather than rebuilding reactively after major failures or incidents. Common characteristics of Stage 3 include:

- Validated coverage and fidelity for required outcome areas
- Durable normalized event representation with recoverable source-native context
- Reliable cross-source pivots for hunting, scoping, and reconstruction
- Resilient and observable transport, processing, and storage paths
- Explicit designation and handling of datasets requiring stronger integrity or evidentiary protections
- Governed policy enforcement for access, minimization, segmentation, and sharing
- Mature schema governance, drift detection, and rollback practices
- Agency Logging Plans that function as decision records and improvement roadmaps rather than static documentation

APPENDIX A: FEDERAL POLICY REFERENCE MAPPINGS

This appendix presents detailed mappings of both current (M-26-14) and previous (M-21-31) federal logging policy elements to the guidance provided in the LRA. Tables A-1 and A-2 are designed to assist agencies in formulating their Agency Logging Plan in accordance with M-26-14, while also aligning progress made under M-21-31 with the objectives established by the LRA.

Table A-1 provides a structured crosswalk between the requirements in OMB Memorandum M-26-14 and the corresponding sections of the LRA. The table is designed to help agencies quickly identify where each policy requirement is addressed within the LRA, including baseline logging expectations, maturity model elements, retention rules, zero trust alignment, AI related considerations, and operational responsibilities such as centralized visibility, sharing obligations, and evidentiary handling. This mapping traces each mandate in the memo to the practical architectural guidance needed to implement CEM and THIRF capabilities effectively and consistently.

Table A-1 - Map of M-26-14 Requirements to the LRA

Topic	M-26-14 Reference	Key Requirement	Relevant LRA Section(s)
Policy and Transition context	Main body (p. 1)	Implements a risk-based, prioritized approach to agency logging and network visibility.	2
CEM Objective	<i>Prioritization: Objective 1</i> (p. 2)	Logging must support CEM, including real-time monitoring, anomaly flagging, and timely response.	3, 3.1, 4.1, 5, 6, 9
THIRF Objective	<i>Prioritization: Objective 2</i> (p. 2)	Logging must support THIRF, including post-compromise analysis, remediation, recovery, and attack-pattern reconstruction.	3, 3.2, 3.3, 3.4, 4.5, 6, 7, 8, 9
Scope of Systems	<i>Prioritization</i> (p. 2)	CEM and THIRF apply to agency-owned, agency-operated, and third-party operated systems, including IoT and OT that are part of agency information systems.	2.1, 5.5, 6, 6.2, Appendix B.1, Appendix D
LRA Implementation Role	<i>Reference Architecture</i> (p. 2)	The LRA is the core source of guidance for implementing CEM and THIRF logging capabilities while preserving mission- and risk-based flexibility.	2, 4, 5, 9, 11
Agency Logging Plan	<i>Agency Logging Plan</i> (p. 3)	Agencies must document how they will meet minimum baseline requirements and identify additional logging activities based on mission, threat environment, and risk profile.	2, 9.4, Appendix B, Appendix B.1
Prioritization	Appendix A: <i>Prioritization</i> (p. 5)	LRA guidance must help agencies prioritize CEM and THIRF implementation, with emphasis on HVAs and High-Impact Systems.	5.5, 9, 9.1, 9.3, Appendix B.1
ZT Alignment	Appendix A: <i>Alignment with Zero Trust</i> (p. 5)	LRA must align with CISA's Zero Trust Maturity Model and support risk-based CEM and THIRF implementation across zero trust pillars.	2, 3, 4.6, 5.5, 6.2, Appendix B.1

Topic	M-26-14 Reference	Key Requirement	Relevant LRA Section(s)
Centralized Access and Visibility	Appendix A: Log Centralization (p. 5); Appendix B: Requirement 2 (p. 6)	LRA must offer centralized access, centralized architecture, or hybrid options, with visibility at the highest-level agency SOC.	4.3, 4.5, 5.4.1, 5.4.2, Appendix B.1, Appendix C
Sensitive Data Protection	Appendix A: Log Collection Containing Risk of Incidental Sensitive Data Exposure (p. 5)	LRA must guide agencies to avoid unlawful log capture or exposure and protect confidentiality and integrity of sensitive log data.	4.6, 5.4.5, 6.2.8, Section 9, Appendix B.1, Appendix E
IoT and OT Logging	Appendix A: IoT and OT (p. 5)	LRA must address IoT and OT logging, including environments and devices without native logging capability.	5.5, 6.2.9, 7.2, Appendix C, Appendix D
AI-enabled Enhancement	Appendix A: Artificial Intelligence (p. 5)	LRA must discuss how AI technologies may enhance CEM and THIRF and reference applicable governmentwide AI policy and guidance.	2, 3.2, 3.3, 3.4, 4, 4.2, 4.4, 7, 10
Self-Assessment	Appendix A: Self-Assessment (p. 5)	LRA must explain how agencies may self-assess CEM, THIRF, and logging maturity.	3.4, 3.5, 11, Appendix C, Appendix D, Appendix E
Above-Minimum Retention	Appendix A: Data Retention Guidance (p. 5)	LRA must provide guidance on retention practices that exceed the minimum requirements.	4.5, 5.3, 9.1, 9.3, 11.1.2, Appendix B.1, Appendix C
Annual LRA Update Cycle	Appendix A: Updates (p. 5)	LRA must be re-evaluated at least annually and adjusted for emerging technologies, threats, frameworks, strategies, and opportunities.	4.7, 11, Appendix B.1, Appendix E
Actively Searchable and Retrievable Retention	Appendix B: Requirement 1 (p. 6)	Retained logs must be actively searchable for at least six months for CEM and retrievable for at least one year for THIRF.	5.1, 5.3, 5.4, 7.4 Appendix B.1, Appendix C, Appendix D, Appendix E
Top-Level SOC Availability	Appendix B: Requirement 2 (p. 6)	Logs may be decentralized, but required logs must be readily available to the top-level agency SOC for CEM and THIRF.	5.1, 5.3, 5.4, 7.4, 11.1, Appendix B.1, Appendix C
Timestamp Accuracy	Appendix B: Requirement 3 (p. 6)	Logs must include consistently accurate timestamps supported by NTP or equivalent synchronization to a traceable agency-designated time source.	4.2, 6.3, 7.1, Appendix D, Appendix E
Coverage using CDM/HWAM/SWAM	Appendix B: Requirement 4 (p. 6)	Agencies should use CDM, HWAM, and SWAM data to determine whether log coverage encompasses agency IT, known IoT, and OT.	3.5, 6.4, 9.2, Appendix C, Appendix E
Baseline Activity Coverage	Appendix B: Requirement 5(a)–(j) (p. 6-7)	Baseline logs must support identity attribution, network attribution, object/resource/data activity, privilege changes, infrastructure changes, security-tool visibility, IOC hunting, anomaly detection, impact assessment, and attack-vector determination.	6, 6.1, 6.2, 6.3, 6.4, Appendix B.1, Appendix D, Appendix E

Topic	M-26-14 Reference	Key Requirement	Relevant LRA Section(s)
Automated Alerts	Appendix B, Requirement 5(k)	Baseline logging must support generation of appropriate automated alerts for the required baseline activities.	3.1, 6.1, 6.2, Appendix D, Appendix E
Log Access for Federal Response	Main Memo: Log Access Requirements	In a known or suspected compromise, agencies must be able to provide logs and relevant data to CISA and FBI upon request, consistent with applicable law.	7.4, 8.2, Appendix B.1, Appendix C, Appendix E
Maturity Model alignment	Main Memo: Measuring Maturity; Appendix C	Agency maturity is measured using inventory visibility, collection coverage, collection operations, data retention, and log management.	3.5, 11, Appendix C, Appendix E
Inventory Visibility Maturity	Appendix C: Inventory Visibility	Maturity depends on the percentage of IT, OT, and IoT assets captured in centralized HWAM/SWAM inventory and update frequency.	3.5, 6.4, 9.2, Appendix E
Collection Coverage Maturity	Appendix C: Collection Coverage	Maturity depends on the percentage of system assets for which Agency Logging Plan-required logs are actively searchable, retrievable, and timely aggregated.	3.5, 6, 11, Appendix C, Appendix E
Collection Operations Maturity	Appendix C: Collection Operations	Maturity depends on actionable alert coverage, use of alerts in investigations, and detection evaluation and tuning.	3.1, 3.5, 6.1, 6.2, 11, Appendix D, Appendix E
Data Retention Maturity	Appendix C: Data Retention	Maturity depends on actively searchable and retrievable retention windows.	4.5, 5.3, 11, Appendix B.1, Appendix E
Log Management Maturity	Appendix C: Log Management	Maturity depends on storage, encryption, integrity controls, just-in-time access, permission review, workload monitoring, and retired-log management.	4.6, 9, 9.1, 9.2, 11, Appendix B.1, Appendix C, Appendix E

Table A-2 presents a structured crosswalk aligning the Appendix C log categories from the rescinded OMB Memorandum 21-31 with relevant content found in Section 6 and Appendix D of the LRA. Despite the formal rescission of M-21-31 by M-26-14, the federal progress achieved under the previous memorandum continues to be vital to the logging objectives established in the LRA. The table details how the previously required log categories correlate with the current guidance and elements within the LRA, illustrating that agency investments in event logging, visibility, and retention remain integral to contemporary CEM and THIRF requirements. This mapping enables agencies to link earlier implementation initiatives to updated architectural and operational decisions needed today, emphasizing that the capabilities developed through M-21-31 are foundational to, and enhanced by, the LRA amid an evolving threat landscape.

Table A-2 - Map of Rescinded M-21-31 Appendix C Log Categories to the LRA

M-21-31 Log Categories	LRA Appendix D Alignment	LRA Section 6 Alignment
Identity & Credential Management	D.2	6.2.1
Privileged Identity & Credential Management	D.2, D.5	6.2.1, 6.2.4
Email Filtering, Spam, and Phishing	D.3, D.7	6.2.2, 6.2.6
Network Device Infrastructure – DHCP	D.3	6.2.2
Network Device Infrastructure – DNS	D.3	6.2.2
Network Device Infrastructure – Passive DNS	D.3	6.2.2
Network Device Infrastructure –WiFi	D.2, D.3	6.2.1, 6.2.2
Network Device Infrastructure – Static NAT/Port Forwarding	D.3	6.2.2
Network Device Infrastructure – General Logging	D.2, D.3, D.6, D.7, D.8	6.2.1, 6.2.2, 6.2.5, 6.2.6, 6.2.7
Network Device Infrastructure – Routers and Switches	D.3	6.2.2
Network Device Infrastructure – Load Balancer/Reverse Proxy	D.3, D.7	6.2.2, 6.2.6
Network Device Infrastructure – Proxies and Web Content Filters	D.3, D.7	6.2.2, 6.2.6
Operating Systems – Windows	D.2, D.3, D.4, D.5, D.6	6.2.1, 6.2.2, 6.2.3, 6.2.4, 6.2.5
Operating Systems – macOS	D.2, D.3, D.4, D.5, D.6	6.2.1, 6.2.2, 6.2.3, 6.2.4, 6.2.5
Operating Systems – Linux/BSD	D.2, D.3, D.4, D.5, D.6	6.2.1, 6.2.2, 6.2.3, 6.2.4, 6.2.5
Cloud Environments – AWS	D.8	6.2.7
Cloud Environments – Azure	D.8	6.2.7
Cloud Environments – GCP	D.8	6.2.7
Configuration – Scripts/Database Changes	D.4, D.5, D.6	6.2.3, 6.2.4, 6.2.5
Endpoint Detection & Response (EDR)	D.6	6.2.5
Authentication – Administrative	D.2, D.3, D.4, D.5, D.7, D.8	6.2.1, 6.2.2, 6.2.3, 6.2.4, 6.2.6, 6.2.7

M-21-31 Log Categories	LRA Appendix D Alignment	LRA Section 6 Alignment
Authorization – Privileged Operations	D.5, D.6	6.2.4, 6.2.5
Email Filtering – Content Filtering Policy Updates	D.5, D.7	6.2.4, 6.2.6
Anti-Virus and Behavior-Based Malware Protection	D.6, D.7	6.2.5, 6.2.6
Anti-Virus – URL/Reputation	D.3, D.7	6.2.2, 6.2.6
Network Device Infrastructure – Firewalls	D.3, D.12	6.2.2, 6.2.9
Network Device Infrastructure – IDS/IPS Alerts and Events	D.3, D.12	6.2.2, 6.2.9
Network Device Infrastructure – VPN Gateway	D.2, D.3, D.12	6.2.1, 6.2.2, 6.2.9
PKI Infrastructure	D.2, D.8	6.2.1, 6.2.7
Vulnerability Assessment	D.5, D.6, D.7	6.2.4, 6.2.5, 6.2.6
Database Level	D.4, D.5, D.6, D.8	6.2.3, 6.2.4, 6.2.5, 6.2.7
Application Level – Web Applications	D.3, D.4, D.7	6.2.2, 6.2.3, 6.2.6
Application Level – Web Application Crashes	D.4, D.6	6.2.3, 6.2.5
Application Level – Middleware	D.4, D.5, D.6	6.2.3, 6.2.4, 6.2.5
Virtualization System	D.2, D.4, D.5, D.8	6.2.1, 6.2.3, 6.2.4, 6.2.7
Mobile – EMM/UEM/MTD Server Logs	D.6, D.7	6.2.5, 6.2.6
Mobile – EMM/UEM/MTD Agent Logs	D.2, D.3, D.4, D.5, D.6	6.2.1, 6.2.2, 6.2.3, 6.2.4, 6.2.5
Container Supply Chain	D.4, D.8	6.2.3, 6.2.7
System Configuration and Performance - System Status	D.4	6.2.3
Email Filtering – Raw and Metadata Events	D.3, D.4, D.8	6.2.2, 6.2.3, 6.2.7
Data Loss Prevention	D.3, D.4	6.2.2, 6.2.3
Network Traffic – Full Packet Capture	D.3	6.2.2
Application Level – COTS/Custom Applications	D.2, D.4, D.5, D.7	6.2.1, 6.2.3, 6.2.4, 6.2.6

M-21-31 Log Categories	LRA Appendix D Alignment	LRA Section 6 Alignment
Application Level – General Non-COTS	D.2, D.4, D.5, D.7	6.2.1, 6.2.3, 6.2.4, 6.2.6
Container – Image	D.3, D.4, D.6, D.7	6.2.2, 6.2.3, 6.2.5, 6.2.6
Container Engine	D.2, D.4, D.5	6.2.1, 6.2.3, 6.2.4
Container OS	D.2, D.3, D.4, D.5, D.6	6.2.1, 6.2.2, 6.2.3, 6.2.4, 6.2.5
System Configuration and Performance – Software Updates	D.4, D.6	6.2.3, 6.2.5
Email, Filtering, Spam, and Phishing – Spam Dictionary Modifications	D.4, D.8	6.2.3, 6.2.7
Mainframes	D.4, D.7, D.12	6.2.3, 6.2.6, 6.2.9
Container Cluster/Pod Events	D.2, D.3, D.4, D.5, D.8, D.9	6.2.1, 6.2.2, 6.2.3, 6.2.4, 6.2.7, 6.2.8

APPENDIX B: AGENCY LOGGING PLAN OVERVIEW

This appendix summarizes the Agency Logging Plan intent, and minimum content agencies should address within the plan. As stated in M-26-14, the Agency Logging Plan is the primary artifact agencies should use to document how they will deploy, maintain, validate, and improve logging capabilities that support CEM and THIRF.

The plan should describe the operational steps the agency will take to meet the minimum baseline requirements in M-26-14, identify any additional log collection or activities needed to achieve CEM and THIRF objectives, and account for the agency's mission, threat environment, risk profile, HVAs, High Impact Systems, and visibility gaps.

B.1 AGENCY LOGGING PLAN TEMPLATE

CISA hosts the Agency Logging Plan template on [CyberScope](#), where agencies will also submit according to the required timelines stated in M-26-14. The template expands the minimum content areas in this appendix into a fillable working format that agencies can use to document the strategy, not implementation details, of their M-26-14 logging plans for their agency. Within this strategic document, it is suggested to include the following topics: logging strategic intent, governance, scope, accountability, CEM and THIRF strategies, logging strategies and coverage, mission/risk based prioritization, enterprise logging and data strategy, security, privacy, integrity, resilience, validation, maturity, performance gaps, and roadmaps.

M-26-14 requires agencies to submit an Agency Logging Plan to OMB and CISA within 90 days of the publication of the LRA. Agencies should follow submission instructions provided by OMB, including any required submission channel, format, naming convention, or supporting artifacts.

After submission, OMB and CISA may use Agency Logging Plans to understand agency implementation posture, identify common gaps or dependencies, inform technical assistance, and support future updates to the LRA or related implementation guidance.

B.2 MINIMUM PLAN CONTENT

CISA recommends the strategic Agency Logging Plan address the content areas below. A template of the document is available on CyberScope.

Table B-1 – Minimum Agency Logging Plan Content

Content Area	Content Scope
Scope and Governance	Plan owner, accountable stakeholders, review cadence, approval status, related artifacts, and the systems, services, assets, environments, and organizational boundaries covered by the plan.
CEM and THIRF Implementation Approach	Operational steps the agency will take to deploy, maintain, and improve logging capabilities that support CEM and THIRF.
Minimum Baseline Implementation	How the agency will meet the M-26-14 minimum baseline requirements, including retention, SOC availability, accurate timestamps, inventory-based coverage, required logging activities, and automated alerts.

Content Area	Content Scope
Additional Mission/Risk-Based Logging	Any additional log collection, fidelity, retention, protection, or operational activities needed based on mission, threat environment, risk profile, visibility gaps, HVAs, or High Impact Systems.
Retention, Access, and Protection	How logs will remain actively searchable and retrievable for required timeframes, how required logs will be made available to the top-level agency SOC, and how sensitive log data will be protected from inappropriate access, exposure, modification, or misuse.
Validation and Maturity Measurement	How the agency will validate that required logs are present, timely, accurate, actively searchable, retrievable, actionable, and protected, and how the agency will measure progress against the M-26-14 maturity model.
Gaps and Improvement Roadmap	Material gaps, affected outcomes or requirements, accountable owners, dependencies, next actions, target milestones, and the path to required maturity levels.

B.3 AGENCY LOGGING PLAN RESOURCES AND CONTACTS

- Updates and future releases of the LRA will be posted to <https://cisa.gov/logging>.
- The Agency Logging Plan template is hosted on <https://cyberscope.cisa.gov/>.
- For questions about the [CyberScope](#) platform, user access, or challenges with finding and submitting the Agency Logging Plan, contact CyberScopeHelp@cisa.dhs.gov.
- For questions about the Agency Logging Plan content, development or agency usage, contact Logging@cisa.dhs.gov.

APPENDIX C: PRIORITY ARCHITECTURE AND DESIGN DECISION CHECKLIST

This appendix provides a concise checklist agencies can use to review the completeness and quality of an Agency Logging Plan and the architectural decisions it documents. The checklist is intended to help agencies determine whether key design decisions have been made explicitly, whether major operational dependencies have been addressed, and whether the proposed capability is likely to be usable and sustainable over time.

C.1 HOW TO USE THIS CHECKLIST

For each item below, reviewers should determine whether the Agency Logging Plan:

- Clearly addresses the decision
- Partially addresses the decision
- Does not adequately address the decision
- Identifies the issue as a gap with an owner and remediation path

A usable plan does not need to claim that every area is complete today. It does need to make the decision explicit or clearly identify the remaining gap.

C.2 OUTCOME ALIGNMENT

Reviewers are encouraged to assess the outcome alignment of their Agency Logging Plan by considering the questions below.

C.2.1 Required Security Outcomes

- Does the plan clearly explain how the logging capability supports continuous event monitoring?
- Does the plan clearly explain how the logging capability supports threat hunting?
- Does the plan clearly explain how the logging capability supports incident response?
- Does the plan clearly explain how the logging capability supports digital forensics?

C.2.2 Operational Questions

- Does the plan identify the operational questions the agency must be able to answer with its logging capability?
- Are those questions tied to concrete data, fidelity, searchability, and retention decisions?
- Are timeliness expectations defined where monitoring or response speed matters?

C.2.3 Enterprise Perspective

- Does the plan describe how enterprise-level visibility will be achieved?
- Does it account for cross-domain operations across identity, endpoint, network, cloud, and administrative planes?
- Does it avoid treating logging as a set of disconnected local tool implementations?

C.3 SCOPE AND COVERAGE

Reviewers should assess the scope and coverage of their Agency Logging Plan with the questions below.

C.3.1 Scope Definition

- Are the environments, systems, services, and organizational boundaries in scope clearly defined?

- Are out-of-scope or deferred environments explicitly identified?
- Is the reason for exclusion or delay documented?

C.3.2 Baseline Coverage

- Does the plan show how baseline logging requirements are satisfied?
- Does it identify the telemetry categories used to meet each baseline requirement?
- Does it address identity, network, endpoint, privileged/admin, cloud/SaaS admin, object/resource/data, and security-tool visibility as applicable?

C.3.3 Specialized and High-Value Environments

- Does the plan address HVAs and other mission-critical systems?
- Does it address specialized environments such as OT, IoT, segmented, remote, or constrained systems where applicable?
- Does it address relevant zero trust policy decisions?
- Does it explain how collection differs in those environments without lowering trustworthiness expectations?

C.4 TELEMETRY FIDELITY AND USABILITY

Reviewers are encouraged to assess their Agency Logging Plan's telemetry fidelity and usability by considering the questions below.

C.4.1 Minimum Event Fidelity

- Does the plan define the minimum event fidelity required for each major telemetry category?
- Does it move beyond source presence to address field completeness, attribution, and usable context?
- Does it identify major fidelity gaps that would weaken investigation, scoping, or reconstruction?

C.4.2 Common Fields for Cross-Source Use

- Does the plan identify the common fields required for cross-source operations?
- Are timestamp, event type, identity or system context, affected resource, outcome, and provenance addressed?
- Are additional fields preserved in support of zero trust policy decisions, where applicable for privilege state, network/session context, request detail, or object-level analysis?

C.4.3 Operational Usability

- Does the plan explain how analysts will pivot across identity, endpoint, network, cloud, and administrative data?
- Does it preserve enough source-native detail for deeper investigation?
- Does it avoid relying solely on alerts or summarized outputs where underlying event context is still needed?

C.5 COLLECTION AND PROVENANCE

Reviewers are encouraged to assess their Agency Logging Plan's collection methods, provenance preservation, and delivery assurance by considering the questions below.

C.5.1 Collection Model

- Does the plan explain where collection occurs for each major telemetry class?
- Does it identify which sources are treated as authoritative?
- Does it account for collection differences across enterprise, cloud, SaaS, and specialized environments?

C.5.2 Provenance Preservation

- Does the plan describe how provenance is preserved from source through downstream handling?
- Are source identity, event time, and collection path recorded or recoverable?
- Does the plan account for transformation history where it materially affects interpretation?

C.5.3 Delivery Assurance

- Does the plan address buffering, retry, restart persistence, or equivalent delivery safeguards?
- Does it describe how missed delivery or collection gaps are detected?
- Does it identify where silent loss could still occur?

C.6 TRANSPORT AND DATAFLOW

Reviewers are encouraged to assess the transport patterns, durability and replay, and enterprise dataflow of their Agency Logging Plan by considering the questions below.

C.6.1 Transport Patterns

- Does the plan specify how telemetry moves through the logging infrastructure?
- Does it distinguish between event-driven delivery, polling, buffering, store-and-forward, and other patterns?
- Are transport decisions tied to the needs of the source and the operational outcome?

C.6.2 Durability and Replay

- Does the plan identify where durable handoff occurs?
- Does it address replay, checkpointing, or backfill mechanisms where needed?
- Does it describe how the architecture behaves during partial failure?

C.6.3 Enterprise Dataflow

- Does the plan explain where collection ends and common downstream handling begins?
- Does it explain how data reaches enterprise analytical or monitoring functions?
- Does it describe how separate enclaves or environments converge into a usable enterprise view?

C.7 NORMALIZATION, ENRICHMENT, AND SCHEMA GOVERNANCE

Reviewers are encouraged to assess the normalization, enrichment, and schema governance of their Agency Logging Plan by considering the questions below.

C.7.1 Normalized Event Representation

- Does the plan identify where normalized event records are produced?
- Does it explain what fields are normalized and why?

- Does it distinguish normalized event records from narrower workflow objects such as alerts or case payloads?

C.7.2 Recoverable Source-Native Context

- Does the plan specify what source-native detail remains recoverable?
- Does it explain where fuller context is preserved and how it is accessed?
- Does it avoid over-flattening records into operationally weak representations?

C.7.3 Enrichment

- Does the plan explain what authoritative enrichment sources are used, such as identity, asset, or configuration data?
- Does it describe how enrichment improves usability without obscuring original event meaning?
- Can analysts distinguish source-provided values from added context where necessary?

C.7.4 Schema Governance

- Does the plan define how new sources are onboarded?
- Does it define required fields and mapping expectations?
- Does it address parser failure, unmapped values, schema drift, and downstream dependency management?

C.8 STORAGE, SEARCHABILITY, AND RETENTION

Reviewers are encouraged to assess the storage, searchability, and retention of their Agency Logging Plan by considering the questions below.

C.8.1 Searchable Operational Window

- Does the plan identify which datasets must remain operationally searchable?
- Does it define how long those datasets remain actively searchable?
- Does it state whether search performance is sufficient for monitoring, hunting, and routine investigation?

C.8.2 Retrievable Retention

- Does the plan identify which datasets may move into lower-cost retrievable storage?
- Does it define retrieval expectations and access paths?
- Does it ensure retrievability supports reconstruction, oversight, and longer-horizon review?

C.8.3 Immutable or Evidentiary Handling

- Does the plan identify which datasets require stronger integrity or immutable handling?
- Does it explain why those datasets are designated that way?
- Does it document access, auditability, and handling expectations for those datasets?

C.8.4 Storage Design Rationale

- Are storage and tiering decisions tied to operational outcomes rather than vendor defaults alone?
- Does the plan distinguish actively searchable retention from retrievable retention clearly?
- Does it identify major cost or scale constraints affecting storage design?

C.9 SECURITY, ACCESS, MINIMIZATION, AND SHARING

Reviewers are encouraged to assess the security, access, minimization and sharing standards of their Agency Logging Plan by considering the questions below.

C.9.1 Logging Infrastructure Protection

- Does the plan identify how the logging infrastructure is protected as a mission-critical capability?
- Are administrative access controls, least privilege, segmentation, and monitoring of privileged actions addressed?
- Does the plan cover more than just the analytics tier, including collection, transport, processing, and storage components?

C.9.2 Integrity and Provenance

- Does the plan explain what integrity protections apply and where?
- Are hashing, signing, immutability, or equivalent controls identified where needed?
- Does the plan describe how provenance is preserved for designated datasets?

C.9.3 Access Control

- Does the plan define who can access what types of log data?
- Are least privilege, separation of duties, and sensitive-data access restrictions addressed?
- Are access logging and auditability covered?

C.9.4 Minimization and Redaction

- Does the plan identify what data must be minimized, redacted, or segmented?
- Does it specify where those controls are applied?
- Does it avoid scattering policy logic inconsistently across multiple tools or paths?

C.9.5 Authorized Sharing

- Does the plan define what logging data may be shared externally and under what conditions?
 - Does it explain how tagging, minimization, redaction, and routing are applied before sharing?
- Are sharing approvals, governance, and auditability addressed?

C.10 VALIDATION, OBSERVABILITY, AND CHANGE CONTROL

Reviewers are encouraged to assess the validation, observability, and change control processes in their Agency Logging Plan by considering the questions below.

C.10.1 Coverage Validation

- Does the plan explain how required sources and categories are validated for presence and completeness?
- Are coverage reviews periodic and repeatable?
- Are gaps tracked explicitly?

C.10.2 Timeliness and Quality Validation

- Does the plan define how timeliness is measured?
- Are timestamp quality, field completeness, parser health, and schema conformance checked?
- Are degraded conditions visible to the agency before they affect operations materially?

C.10.3 Operational Usability Validation

- Does the plan explain how the agency verifies that analysts can perform required pivots and investigations?
- Are synthetic tests, replay tests, exercises, or equivalent validation methods used?
- Does the plan validate searchability and retrieval in practice rather than assume they work?

C.10.4 Drift and Change Management

- Does the plan identify how source, parser, and schema changes are introduced?
- Are rollback or mitigation procedures defined?
- Does the plan describe how operational regressions will be detected after change?

C.11 ABOVE-BASELINE LOGGING DECISIONS

Reviewers are encouraged to assess their above-baseline logging decisions by considering the questions below.

C.11.1 Decision Basis

- Does the plan explain where the agency has chosen to go above baseline?
- Are those decisions justified by mission, threat, risk, or visibility considerations?
- Are they documented clearly enough that another team could understand the rationale?

C.11.2 Investigative Use Case Linkage

- Does the plan connect above-baseline telemetry to specific investigative or operational questions?
- Does it explain what those additional data sources or fidelity levels enable?
- Does it avoid treating above-baseline logging as ad hoc accumulation?

C.11.3 Integration Into the Architecture

- Does the plan show how above-baseline telemetry is collected, transported, normalized, stored, protected, and validated?
- Are retention and cost implications addressed?
- Is above-baseline telemetry available to the teams that need it?

C.12 MATURITY AND IMPROVEMENT

Reviewers should assess their Agency Logging Plan's maturity and improvement schema using the questions below.

C.12.1 Current State

- Does the plan state the agency's current maturity stage or equivalent current-state view?
- Does it describe the evidence supporting that assessment?
- Does it identify the largest operational gaps honestly?

C.12.2 Improvement Priorities

- Does the plan identify the highest-priority improvements for the next planning cycle?
- Are those priorities tied to the largest risks to detection, threat hunting, incident response, or forensics?

- Are dependencies and constraints identified?

C.12.3 Governance and Review

- Does the plan identify ownership and review cadence?
- Does it define what events trigger plan updates?
- Does it treat the plan as a living decision record rather than a static artifact?

C.13 REVIEWER SUMMARY

At the end of the review, reviewers should be able to answer the following high-level questions:

1. Does the Agency Logging Plan clearly explain how the agency's logging capability supports monitoring, threat hunting, incident response, and forensics?
2. Does it make the key architectural, retention, integrity, access, and validation decisions explicit?
3. Does it identify what is still incomplete and how those gaps will be addressed?
4. Would an implementation team be able to use this plan to build, validate, or improve the capability without having to infer major design decisions?

If the answer to any of these is no, the plan likely needs additional specificity before it can serve as a reliable implementation and governance artifact.

APPENDIX D: BASELINE LOGGING CATEGORIES AND MINIMUM FIDELITY QUICK REFERENCE

This appendix provides a concise reference for the baseline logging categories agencies should address and the minimum event fidelity required to make those categories operationally useful.

This appendix is intended to support:

- Agency Logging Plan development
- Architecture and engineering reviews
- Source onboarding and validation
- Gap identification and prioritization
- Baseline coverage assessments

This appendix is not a substitute for the fuller discussion in the main body. It is a quick reference intended to help agencies determine whether they have the right categories of telemetry and whether those categories preserve enough detail to support required outcomes.

D.1 HOW TO USE THIS APPENDIX

For each baseline logging category, agencies should confirm four things:

1. **Coverage**
Does the agency collect this category for the relevant systems, services, and environments?
2. **Minimum usable fidelity**
Do event records preserve the minimum fields and context needed for correlation, scoping, and reconstruction?
3. **Operational accessibility**
Is the data available in the right timeframes and storage tiers for monitoring, threat hunting, incident response, and forensics?
4. **Known weaknesses**
What failure modes still materially weaken the agency's ability to use this category?

D.2 IDENTITY AND AUTHENTICATION ACTIVITY

Reviewers should confirm the coverage, minimum usable fidelity, operational accessibility, and known weaknesses of their plan's identity and authentication activity using the following standards.

D.2.1 Operational Purpose

Supports:

- Identity attribution
- Detection of suspicious access behavior
- Monitoring of authentication attempts and outcomes
- Threat hunting for credential misuse
- Correlation of user and service activity
- Reconstruction of authentication and access sequences

D.2.2 Minimum Usable Fidelity

Records should preserve, at a minimum:

- Timestamp
- Identity or principal context
- Authentication or access event type
- Outcome or result
- Source system or service
- Source device, source IP, or session context where available

D.2.3 Additional Fidelity Often Needed

- MFA context
- Token issuance or assertion details
- Session identifiers
- Device posture or trust context
- Risk signals used in access decisions
- Privileged-role activation or identity change context

D.2.4 Common Operational Failure Modes

- Identities cannot be correlated across systems.
- Authentication outcomes are present, but session or source context is missing.
- MFA or token-related events are incomplete.
- Service and non-person identities are poorly represented.
- Timestamps are inconsistent across major identity sources.

D.3 NETWORK ACTIVITY

Reviewers should confirm the coverage, minimum usable fidelity, operational accessibility, and known weaknesses of their plan's network activity using the following standards.

D.3.1 Operational Purpose

Supports:

- Source and destination attribution
- Communication-path reconstruction
- Lateral-movement analysis
- Suspicious destination or protocol analysis
- IOC scoping
- Connection or session tracing during incident response

D.3.2 Minimum Usable Fidelity

Records should preserve, at a minimum:

- Timestamp
- Source address
- Destination address
- Protocol
- Port
- Session or connection attributes where available

D.3.3 Additional Fidelity Often Needed

- Directionality
- NAT or translation context
- DNS resolution context
- User or host linkage
- Connection duration or byte counts
- Segmentation or zone context

D.3.4 Common Operational Failure Modes

- Only coarse summaries are available.
- Connection context is insufficient to support path reconstruction.
- Network records cannot be tied to identities or hosts.
- Important east-west traffic is not visible.
- Timing quality is too weak for correlation with endpoint or identity activity.

D.4 OBJECT, RESOURCE, AND DATA ACTIVITY

Reviewers should confirm the coverage, minimum usable fidelity, operational accessibility, and known weaknesses of their plan's object, resource, and data activity using the following standards.

D.4.1 Operational Purpose

NOTE: "Created" and "exfiltrated" activity is included in the LRA to support complete forensic and impact analysis, but these elements extend beyond the explicit minimums of M-26-14 Requirement 5(c).

Supports:

- Integrity monitoring
- Data and resource access analysis
- Incident impact assessment
- Scoping of accessed, modified, created, exfiltrated, or destroyed items
- Investigation of suspicious data activity

D.4.2 Minimum Usable Fidelity

Records should preserve, at a minimum:

- Timestamp
- Object, resource, or data context
- Action performed
- Associated identity or system context
- Outcome where applicable

D.4.3 Additional Fidelity Often Needed

- Object path or identifier
- Classification or sensitivity context
- Volume or transfer context
- Source and destination context for copied or moved data
- Application or service context involved in the action

D.4.4 Common Operational Failure Modes

- Records show that something happened, but not to what object or dataset.
- Object-level detail is too coarse for impact assessment.
- Data activity cannot be tied to actor or system context.
- Bulk transfers or mass modifications are not distinguishable from routine actions.
- Data-focused events are retained but not actively searchable enough for reconstruction.

D.5 PRIVILEGED AND ADMINISTRATIVE ACTIVITY

Reviewers should confirm the coverage, minimum usable fidelity, operational accessibility, and known weaknesses of their plan's privileged and administrative activity using the following standards.

D.5.1 Operational Purpose

Supports:

- Attribution of administrative or privileged actions.
- Detection of privilege escalation or unauthorized changes.
- Monitoring of authoritative system and service changes.
- Incident scoping and trust restoration.

D.5.2 Minimum Usable Fidelity

Records should preserve, at a minimum:

- Timestamp
- Actor identity
- Privileged or administrative action
- Target resource, system, or service
- Outcome or result

D.5.3 Additional Fidelity Often Needed

- Pre-change and post-change state
- Source system or administrative interface
- Approval or workflow context
- Session or request identifiers
- Privilege context of the actor at the time of action

D.5.4 Common Operational Failure Modes

- Changes are recorded but not attributable to an actor.
- Actor identity exists but target context is weak or missing.
- Administrative actions across cloud, SaaS, and enterprise systems are not correlated.
- Privilege changes and configuration changes are logged in different places with incompatible meaning.
- Records are present but too shallow to restore trust after a compromise.

D.6 ENDPOINT AND SYSTEM ACTIVITY

Reviewers should confirm the coverage, minimum usable fidelity, operational accessibility, and known weaknesses of their plan's endpoint and system activity using the following standards.

D.6.1 Operational Purpose

Supports:

- Host-level activity visibility
- Process and execution monitoring
- Detection of suspicious system changes
- Reconstruction of attack sequences on systems
- Infrastructure change awareness

D.6.2 Minimum Usable Fidelity

Records should preserve, at a minimum:

- Timestamp
- Device or system identity
- Activity or process context
- Associated identity or system context where available
- Action or result

D.6.3 Additional Fidelity Often Needed

- Process lineage
- Command-line arguments
- Parent-child relationships
- Service or scheduled task context
- File or registry context
- Integrity or policy status context

D.6.4 Common Operational Failure Modes

- Host activity exists only as summarized alerts.
- Process execution details are too sparse for hunting or scoping.
- Device identity is inconsistent across sources.
- System changes cannot be tied to the responsible identity or tool.
- Endpoint telemetry is not preserved long enough in actively searchable form.

D.7 SECURITY TOOL ALERTS AND DETECTIONS

Reviewers should confirm the coverage, minimum usable fidelity, operational accessibility, and known weaknesses of their plan's security tool alerts and detections using the following standards.

D.7.1 Operational Purpose

Supports:

- Alert triage
- Prioritization and workflow initiation

- Enrichment of investigations
- Correlation between analytic detections and raw events
- Operational awareness of suspicious activity identified by security tools

D.7.2 Minimum Usable Fidelity

Records should preserve, at a minimum:

- Timestamp
- Alert or detection type
- Source security tool
- Affected asset, account, or resource where applicable
- Severity or priority where available
- Enough analytic context to understand why the alert was generated

D.7.3 Additional Fidelity Often Needed

- Rule or analytic identifier
- Detection rationale or matched condition
- Related entities
- Confidence or analytic metadata
- Links or references to underlying event data

D.7.4 Common Operational Failure Modes

- Alerts exist without access to the underlying event context.
- Analytic rationale is too weak to support triage.
- Tool-specific severity values do not translate well across the enterprise.
- Alerts are treated as a substitute for the underlying logging category.
- Detections cannot be validated or scoped because raw or richer data is unavailable.

D.8 CLOUD AND SAAS ADMINISTRATIVE ACTIVITY

Reviewers should confirm the coverage, minimum usable fidelity, operational accessibility, and known weaknesses of their plan's cloud and SaaS administrative activity using the following standards.

D.8.1 Operational Purpose

Supports:

- Attribution of cloud and SaaS administrative actions
- Control-plane monitoring
- Change detection
- Investigation of unauthorized or suspicious use of administrative capabilities
- Correlation of identity and administrative activity across environments

D.8.2 Minimum Usable Fidelity

Records should preserve, at a minimum:

- Timestamp
- Actor identity
- Administrative or control-plane action

- Target resource or service
- Outcome or result
- Request or session context where available

D.8.3 Additional Fidelity Often Needed

- API request parameters
- Tenant or subscription context
- Identity assertion details
- Originating network or device context
- Role assignment or delegation context

D.8.4 Common Operational Failure Modes

- Control-plane activity is incompletely collected.
- Request details are too sparse to understand what changed.
- Cloud administrative events cannot be correlated to enterprise identity context.
- Provider-side changes introduce drift without detection.
- Data exists only through delayed API retrieval that weakens timeliness.

D.9 HIGH VALUE ASSETS AND SPECIALIZED ENVIRONMENTS

Reviewers should confirm the coverage, minimum usable fidelity, operational accessibility, and known weaknesses of their plan's high value assets and specialized environments using the following standards.

D.9.1 Operational Purpose

Supports:

- Stronger visibility for mission-critical systems and services
- Detection and reconstruction in environments with elevated mission impact
- Specialized monitoring in OT, IoT, segmented, or constrained environments
- Risk-informed expansion beyond the baseline

D.9.2 Minimum Usable Fidelity

Records should preserve, at a minimum:

- Timestamp
- Identity, system, or operator context
- Relevant activity or change context
- Target asset, controller, service, or device
- Outcome or state change where applicable
- Provenance sufficient to support trust in the source and collection path

D.9.3 Additional Fidelity Often Needed

- Engineering workstation context
- Firmware or controller configuration changes
- Specialized command sequences
- System safety or operational state context
- Gateway or intermediary context where direct collection is not possible

D.9.4 Common Operational Failure Modes

- Collection is adapted for the environment, but trustworthiness is reduced too far.
- Timing, provenance, or asset identity is weak because of gateway aggregation.
- Specialized events are collected but not integrated into enterprise investigation workflows.
- HVA logging is not materially stronger than general enterprise logging.
- Constrained environments are left out of validation because collection is difficult.

D.10 COMMON FIELDS REQUIRED ACROSS CATEGORIES

Regardless of category, agencies should preserve a minimum common field set that enables cross-source search, correlation, and triage.

D.10.1 Minimum Common Field Set

- Timestamp
- Event or action type
- Identity or system context where applicable
- Affected resource, device, service, or dataset where applicable
- Outcome or result where applicable
- Provenance

D.10.2 Validation Prompts

- Are these fields present and usable across the major baseline categories?
- Are the field meanings stable enough for correlation across sources?
- Are timestamps reliable enough for cross-source sequence reconstruction?
- Is provenance preserved in a way that allows analysts to understand where the record came from and how it entered the logging infrastructure?

D.11 QUICK GAP IDENTIFICATION PROMPTS

Agencies can use the prompts below as a fast screen for material baseline weaknesses.

D.11.1 Coverage

- Which baseline categories are only partially covered today?
- Which environments are missing one or more baseline categories entirely?
- Are HVAs or mission-critical cloud services treated differently enough to reflect their risk?

D.11.2 Fidelity

- Which categories lack enough detail for real investigation or reconstruction?
- Where are key fields missing, unreliable, or inconsistently mapped?
- Which categories exist mainly as summaries or alerts rather than usable event records?

D.11.3 Searchability and Access

- Which categories are retained but not actively searchable?
- Which categories are present only in isolated tools or enclaves?
- Which categories are inaccessible to the enterprise SOC or central investigative function?

D.11.4 Correlation

- Which categories cannot be reliably correlated across identity, endpoint, network, cloud, and administrative sources?
- Where do entity identifiers or timestamps break enterprise pivots?
- Which categories most frequently require manual reconciliation?

D.12 IOT AND OT DEVICES

D.12.1 Operational Purpose Support

- Visibility into device or controller-level activity
- Detection of configuration or state changes
- Correlation of IoT/OT behavior with identity
- Reconstruction of activity where native logging is limited or absent

D.12.2 Minimum Usable Fidelity

Records should preserve, at a minimum:

- Timestamp
- Device, controller, or operator identity
- Relevant activity, state, or configuration context
- Provenance, including gateway or intermediary path where direct collection is not possible

D.12.3 Additional Fidelity Often Needed

- Gateway-provided context or logs
- Store-and-forward timing metadata
- Network-based observations (e.g., command/traffic patterns)
- Engineering or workstation or operator context

D.12.4 Common Operational Failure Modes

- Absence of native logs due to device constraints
- Weak provenance when relying on gateway aggregation
- Insufficient context to correlate IoT/OT activity with enterprise identity or network activity
- Failure to preserve timestamp consistency across constrained environments

D.13 RECOMMENDED USE IN AGENCY LOGGING PLANS

Agencies should use this appendix to summarize their baseline coverage posture in a concise table or implementation matrix. At a minimum, the Agency Logging Plan should provide the following for each category:

- Whether the category is in scope
- Which environments or systems it covers
- The minimum usable fidelity required
- Current known material gaps
- Whether the category is actively searchable, retrievable, or both
- Any above-baseline enhancements applied to the category

This gives reviewers and implementers a quick way to distinguish between nominal coverage and usable coverage.

APPENDIX E: VALIDATION AND OPERATIONAL READINESS CHECKLIST

This appendix provides a practical checklist agencies can use to validate whether the enterprise logging capability described in the Agency Logging Plan is functioning as intended and is operationally ready to support required security outcomes. This appendix is not a compliance scorecard. It is a readiness and assurance tool.

This checklist is intended to help agencies answer questions, such as:

- Are required telemetry sources present and producing usable records?
- Is data arriving in time to support monitoring and response?
- Is event fidelity sufficient for investigation and reconstruction?
- Can analysts search, pivot, retrieve, and validate the data they need?
- Are integrity, provenance, and access protections working as intended?
- Can the agency detect when the logging capability has degraded?
- Can the agency safely change the capability without silently breaking it?

E.1 HOW TO USE THIS CHECKLIST

A mature validation program does not assume that because a connector exists or a source is onboarded, the data is present, timely, and usable. For each item below, reviewers should determine whether the capability is:

- Validated
- Partially validated
- Not yet validated
- Known gap with remediation plan

Validation should be based on evidence where possible, such as:

- Successful tests
- Synthetic events
- Replay exercises
- Operational drills
- Data quality checks
- Search and retrieval demonstrations
- Incident or exercise observations
- Documented review artifacts

E.2 SCOPE AND COVERAGE VALIDATION

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.2.1 In-Scope Environment Validation

- Has the agency validated that all in-scope environments identified in the Agency Logging Plan are represented in the logging capability?
- Are enterprise, cloud, SaaS, mission, and specialized environments covered as described in the plan?
- Are out-of-scope or deferred environments explicitly identified and tracked?

E.2.2 Baseline Category Coverage Validation

- Has the agency validated that each baseline logging category is covered for the appropriate systems and environments?
- Are identity, network, endpoint/system, privileged/admin, cloud/SaaS admin, object/resource/data, and security-tool categories present where expected?
- Has the agency identified any baseline categories that are only partially present or inconsistently available?

E.2.3 High-Value and Specialized Environment Validation

- Has the agency validated that HVAs, mission-critical systems, or specialized environments receive the intended level of logging coverage?
- Are constrained environments handled through validated alternate collection patterns rather than undocumented exceptions?
- Are key blind spots for those environments documented and prioritized?

E.3 SOURCE PRESENCE AND COLLECTION VALIDATION

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.3.1 Source Onboarding Validation

- Has each required source or source class been validated as onboarded successfully?
- Is the agency relying on authoritative sources where intended?
- Are source owners and data dependencies known?

E.3.2 Collection Integrity Validation

- Has the agency validated that collection occurs where planned?
- Is source identity preserved through collection?
- Are collection paths documented and testable?

E.3.3 Gap Detection

- Can the agency detect when a required source stops sending data?
- Can it detect reduced event volume, missing event classes, or intermittent delivery from a source?
- Are collection failures visible to operators before they materially affect monitoring or response?

E.4 TIMELINESS AND LATENCY VALIDATION

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.4.1 Event Arrival Timeliness

- Has the agency validated that events arrive within the timeframes required for their intended operational use?
- Are latency thresholds defined for major telemetry categories?
- Are those thresholds measured continuously or at regular intervals?

E.4.2 Delay and Backlog Detection

- Can the agency detect transport delay, processing backlog, indexing lag, or retrieval delay?
- Are queue depth, backlog age, or equivalent indicators monitored?
- Is there a documented response process when timeliness degrades?

E.4.3 Polling and Retrieval Validation

- For sources that use polling or scheduled retrieval, has the agency validated that the cadence is sufficient for the outcome being supported?
- Has the agency measured lag introduced by API-based or scheduled collection?
- Are missed windows, provider-side changes, or retrieval failures visible?

E.5 EVENT FIDELITY AND DATA QUALITY VALIDATION

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.5.1 Minimum Field Validation

- Has the agency validated that required common fields are present across the major telemetry categories?
- Are timestamp, event type, identity/system context, affected resource, outcome, and provenance fields populated where expected?
- Are required category-specific fields validated as well?

E.5.2 Timestamp Validation

- Has the agency validated timestamp quality and consistency across major sources?
- Are timestamps reliable enough to support cross-source reconstruction?
- Are time-synchronization or time-zone issues documented?

E.5.3 Parsing and Mapping Validation

- Has the agency validated that fields are parsed and mapped correctly?
- Are unmapped values, parser failures, or malformed records visible?
- Is field meaning stable across updates?

E.5.4 Fidelity Sufficiency Validation

- Has the agency validated that records preserve enough detail to support triage, threat hunting, scoping, and reconstruction?
- Can analysts reach source-native context when normalized records are not enough?
- Are any categories present only as weak summaries or alerts without enough underlying event detail?

E.6 SCHEMA, NORMALIZATION, AND CORRELATION VALIDATION

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.6.1 Normalized Event Validation

- Has the agency validated that normalized event records exist where intended?
- Are normalized records durable and operationally usable?
- Are normalized records sufficient for routine cross-source pivots?

E.6.2 Source-Native Context Validation

- Has the agency validated that richer source-native context remains recoverable where needed?
- Can analysts retrieve original or equivalent detailed event context during investigations?
- Are recovery paths documented and usable under pressure?

E.6.3 Entity Correlation Validation

- Can the agency correlate activity across identity, endpoint, network, cloud, and administrative datasets?
- Are shared identifiers usable in practice?
- Are there common situations where analysts still must manually reconcile core entities?

E.6.4 Drift Detection Validation

- Has the agency validated its ability to detect schema drift or changed field meaning?
- Are parser and mapping regressions surfaced operationally?
- Are downstream detections, dashboards, or workflows tested when source schemas change?

E.7 SEARCHABILITY AND RETRIEVAL VALIDATION

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.7.1 Searchability Validation

- Has the agency validated actively searchable datasets remain available in the intended low-latency tiers?
- Can analysts perform expected search and pivot actions within operationally useful timeframes?
- Are query performance expectations documented and tested?

E.7.2 Retrieval Validation

- Has the agency validated retrievable datasets that can be retrieved within the expected timeframe?
- Are restored or retrieved datasets complete and usable?
- Are retrieval paths exercised periodically rather than assumed?

E.7.3 Searchability vs. Retrieval Distinction

- Has the agency validated that datasets intended only for retrieval, are not being mistakenly treated as actively searchable?
- Are operators clear on what is actively searchable versus what requires retrieval?
- Are expectations aligned with the Agency Logging Plan?

E.8 OPERATIONAL USABILITY VALIDATION

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.8.1 Monitoring Use Case Validation

- Can the agency's monitoring teams use the data to identify suspicious activity in operationally relevant timeframes?
- Do alerts include enough context to support triage?
- Can teams move from alert to supporting event data without excessive manual effort?

E.8.2 Threat Hunting Validation

- Can analysts search and pivot across the datasets needed for threat hunting?
- Are required hunt-ready fields and contexts available?
- Can analysts perform representative hunt workflows without depending on ad hoc data recovery?

E.8.3 Incident Response Validation

- Can responders reconstruct timelines and scope affected systems, identities, and data?
- Can the agency pivot from alerts into correlated supporting datasets quickly enough to support containment decisions?
- Are investigative workflows impeded by missing or inaccessible data?

E.8.4 Digital Forensics Validation

- Can investigators reconstruct key events with sufficient confidence using retained data?
- Are designated forensic or evidentiary datasets preserved as intended?
- Is supporting context, such as inventories or baseline information, accessible when needed?

E.9 INTEGRITY, PROVENANCE, AND ACCESS VALIDATION

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.9.1 Integrity Control Validation

- Has the agency validated that required integrity protections are functioning as intended?
- Are hashing, signing, immutability, or equivalent protections applied where designated?
- Can the agency detect unauthorized modification or integrity loss where such controls are expected?

E.9.2 Provenance Validation

- Can the agency trace records back to their origin and handling path where needed?
- Are meaningful transformations documented or recoverable?
- Does the agency know when provenance is insufficient for trust-sensitive use cases?

E.9.3 Access Control Validation

- Has the agency validated that access restrictions work as intended?
- Are least privilege and separation-of-duties controls enforced for sensitive log data?
- Are privileged and sensitive-data access events logged and reviewable?

E.9.4 Minimization and Sharing Validation

- Has the agency validated that minimization, redaction, segmentation, and sharing controls are applied at the intended enforcement points?
- Are external or boundary-crossing data flows governed and auditable?
- Are policy-controlled views or subsets operating as intended?

E.10 PIPELINE HEALTH AND RESILIENCE VALIDATION

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.10.1 Health Monitoring Validation

- Does the agency monitor the health of major pipeline stages such as collection, transport, processing, storage, and analytics?
- Are failures visible quickly enough for intervention?
- Are health indicators tied to operational escalation paths?

E.10.2 Partial Failure Validation

- Has the agency validated how the pipeline behaves under partial failure?
- Can the agency identify what data is delayed, degraded, or at risk during component failure?
- Are degraded-mode behaviors documented?

E.10.3 Buffering and Replay Validation

- Has the agency validated buffering, queueing, replay, or backfill mechanisms where they are required?
- Can missed or delayed data be recovered as intended?
- Are replay and backfill tested periodically?

E.10.4 Single-Point Fragility Validation

- Has the agency identified fragile chokepoints in the pipeline?
- Has it validated whether failure of a key component causes silent loss or enterprise-wide blindness?
- Are mitigation or recovery steps documented?

E.11 CHANGE MANAGEMENT AND REGRESSION VALIDATION

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.11.1 Controlled Change Validation

- Are source onboarding, parser changes, field mapping changes, and storage/pipeline changes introduced through governed processes?
- Are changes reviewed for downstream impact before rollout?
- Are rollback paths defined?

E.11.2 Regression Testing

- Does the agency perform regression testing for major changes affecting schema, ingestion, or operational content?
- Are representative monitoring, threat hunting, incident response, and retrieval use cases re-tested after change?
- Are failures or regressions surfaced to the right owners?

E.11.3 Post-Change Review

- After changes are deployed, does the agency validate that expected data is still present, timely, and usable?
- Are dashboards, detections, workflows, and retrieval paths checked for breakage?
- Is drift overtime reviewed rather than assumed away?

E.12 EXERCISES, SYNTHETIC TESTS, AND READINESS DEMONSTRATIONS

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.12.1 Synthetic Event Validation

- Does the agency inject or generate representative events to confirm collection, parsing, and downstream handling?
- Are synthetic tests tied to expected source categories and investigative workflows?
- Are failed synthetic tests tracked to remediation?

E.12.2 Tabletop and Exercise Support Validation

- Do exercises and incident-response drills use the actual logging capability as part of validation?
- Are lessons learned from those exercises fed back into logging design and validation?
- Are exercises used to validate cross-team access and coordination, not just technical presence?

E.12.3 Replay and Historical Validation

- Can the agency use historical or replayed data to validate pipeline behavior and investigative usability?
- Are restoration and replay paths exercised often enough to remain trustworthy?
- Is there evidence or documentation that the agency possesses capabilities necessary to reconstruct prior time windows when needed?

E.13 GAP TRACKING AND IMPROVEMENT VALIDATION

Researchers should determine whether the following capabilities are validated, partially validated, not yet validated, or a known gap with a remediation plan.

E.13.1 Known Gap Visibility

- Are known gaps in source coverage, fidelity, access, correlation, or retention documented explicitly?
- Are those gaps visible to both technical and governance stakeholders?
- Are high-impact gaps prioritized?

E.13.2 Remediation Tracking

- Does each known material gap have an owner, remediation path, and review cadence?
- Is improvement progress tied to measurable outcomes rather than generic status statements?
- Are unresolved dependencies or funding constraints documented?

E.13.3 Maturity Progress Validation

- Has the agency identified what maturity stage best describes its current logging capability?
- Is there evidence of movement toward the next stage?
- Are validation results being used to refine the maturity assessment over time?

E.14 HIGH-LEVEL READINESS QUESTIONS

At the end of the review, the agency should be able to answer the following questions with evidence. If the answer to any of these is no, the agency should treat that as a material readiness issue, not just a documentation gap.

1. Are the required baseline telemetry categories present across the intended environments?
2. Is the data timely enough, complete enough, and detailed enough to support monitoring, threat hunting, incident response, and digital forensics?
3. Can analysts and responders search, pivot, retrieve, and reconstruct activity using the datasets the plan says they depend on?
4. Are integrity, provenance, access, minimization, and sharing controls working as intended?
5. Can the agency detect when the logging capability is degraded and recover from that degradation?
6. Can the agency introduce change without silently breaking critical operational use cases?

APPENDIX F: ACRONYMS

Acronym	Meaning
ABAC	Attribute-Based Access Control
AI	Artificial Intelligence
API	Application Programming Interface
ASD	Australian Signals Directorate
AWS	Amazon Web Services
BSD	Berkeley Software Distribution
CDM	Continuous Diagnostics and Mitigation
CEM	Continuous Event Monitoring
CISA	Cybersecurity and Infrastructure Security Agency
CISO	Chief Information Security Officer
CLAW	Cloud Log Aggregation Warehouse
COTS	Commercial-Off-The-Shelf
CSF	Cybersecurity Framework
CUI	Controlled Unclassified Information
DHCP	Dynamic Host Configuration Protocol
DNS	Domain Name System
EDR	Endpoint Detection and Response
EMM	Enterprise Mobility Management
EO	Executive Order
FBI	Federal Bureau of Investigation
FCEB	Federal Civilian Executive Branch
GCP	Google Cloud Platform
HVA	High Value Assets
HWAM	Hardware Asset Management
IaaS	Infrastructure-as-a-Service
IDS	Intrusion Detection System

Acronym	Meaning
IOC	Indicator of Compromise
IoT	Internet of Things
IPS	Intrusion Prevention System
IT	Information Technology
LLM	Large Language Model
LRA	Logging Reference Architecture
MFA	Multifactor Authentication
ML	Machine Learning
MNGEVT	Manage Events
MSP	Managed Service Provider
MTD	Mobile Threat Defense
NAT	Network Address Translation
NIST	National Institute of Standards and Technology
NTP	Network Time Protocol
OMB	Office of Management and Budget
OT	Operational Technology
PaaS	Platform-as-a-Service
PII	Personally Identifiable Information
PKI	Public Key Infrastructure
RBAC	Role-Based Access Control
SaaS	Software-as-a-Service
SIEM	Security Information and Event Management
SOAR	Security Orchestration, Automation, and Response
SOC	Security Operations Center
SP	Special Publication
SWAM	Software Asset Management
THIRF	Threat Hunting, Investigation, Response, and Forensics

Acronym	Meaning
TTPs	Tactics, Techniques, and Procedures
UEM	Unified Endpoint Management
VPN	Virtual Private Network
ZT	Zero Trust
ZTA	Zero Trust Architectures
ZTMM	Zero Trust Maturity Model